**UNIVERSITE DE FIANARANTSOA**

**ECOLE NATIONALE D'INFORMATIQUE**

**MEMOIRE DE FIN D'ETUDE POUR L'OBTENTION DE DIPLOME DE MASTER PROFESSIONNEL**

**Mention :** Intelligence Artificielle

**Parcours :** Object Connecté et CyberSécurité

Intutilé :

# *Mysa: Une architecture autonome de cybersécurité comportementale pour les écosystèmes de maisons intelligentes*

**Presenté le :** 23 Novembre 2026

**Par :** Mademoiselle, **SAMARTINA** Eldinha Reinitha

**Membres de Jury :**

**Président :** Monsieur, RAZJNFJNRDK JNFKD, Docteur

**Examinateur :** Monsieur, hfhdhfdhfi

**Rapporteurs :** Madame, **RATIANANTITRA** Volatiana Marielle, Maître de Conférences

Monsieur, **ANDRIANTSIALO** Elyah Frisco

Année universitaire 2025-2026

# Curriculum Vitae



**Nom : SAMARTINA**

**Prénoms :** Eldinha Reinitha

**Date et lieu de naissance :** 18 Mai 2004 à Vohiposa

**Adresse :** 580A/3710 Ampitakely Fianarantsoa

**Tel :** 038 50 122 52

**E-mail :** reinithaeldinha@gmail.com

**FORMATIONS ET DIPLOME**

**2025-2026 :** Deuxième année en master professionnelle à l'ENI Fianarantsoa en parcours Objet connecté et CyberSécurité, mention Intelligence Artificielle.

**2024-2025 :** Première année en master professionnelle à l'ENI Fianarantsoa en parcours Objet connecté et CyberSécurité, mention Intelligence Artificielle.

**2023-2024 :** Troisième année en licence professionnelle à l'ENI Fianarantsoa en parcours Informatique Générale, mention Informatique.

**2022-2023 :** Deuxième année en licence professionnelle à l'ENI Fianarantsoa en parcours Informatique Générale, mention Informatique.

**2021-2022 :** Première année en licence professionnelle à l'ENI Fianarantsoa en parcours Informatique Générale, mention Informatique.

**2020-2021 :** Diplôme de baccalauréat série C avec mention assez bien au Lycée Sacré Cœur Ambohimasoa

**STAGES ET EXPERIENCES PROFESSIONNELLES**

**01 Juin 2026 - Maintenant :** Technicienne en CyberSécurité au sein du groupe Rajaballi Antananarivo dont la mission consiste à l'analyse de vulnérabilité, analyse de risque et remédiation, investigation d'incident et mise en place de solution de sécurité.

**01 Décembre 2025-31 Mai 2026 :** Stage en IoT au sein de l'UN-IT Fianarantsoa dont le projet consiste sur la mise en place de système de pointage avec empreinte digitale relié avec le CRM interne.

**23 Septembre 2024-30 Novembre 2024 :** Stage en administrateur système et réseaux au sein du Cabinet EXTER Antananarivo dont le projet consiste sur la centralisation de données en mettant en place un serveur de fichier sécurisé.

**Septembre 2023-Novembre 2023 :** Stage de développeur au sein du CIDST Antananarivo avec laquelle la conception et la réalisation de la gestion des outils informatiques a été effectué.

## COMPETENCES EN INFORMATIQUE

**Systèmes d'exploitation :** Windows, Linux, Windows Server

**Bureautiques :** Microsoft word, Excel, PowerPoint

**Langages de programmation :** Python, java, C, C++ et C#

**Technologies Web :** HTML, CSS, Javascript et PHP

**Frameworks :** Django, ReactJS et NodeJS

**Systèmes de gestion de base de données :** MySql, PostgreSQL

**Outils :** VMWare, GNS3, Wireshark, NMAP, BurpSuite, Nikto, …

**Méthodes de conception :** Merise et 2TUP

**Langage de conception :** UML et Agile

**Cyber-securite :** Analyse de vulnérabilité, évaluation de risque et remédiation, investigation d'incident, …

**Intelligence Artificielle :** Apprentissage automatique (scikit-learn, Isolation Forest), détection d'anomalies

## CONNAISSANCES LUNGUISTIQUES

Tableau 1 : Connaissance lunguistiques

| **Langues** | **Comprendre à l'audition** | | | | | **Lire** | | | | | **Ecrire** | | | | | **Parler et communiquer** | | | | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| | **TB** | **B** | **AB** | **P** | **NS** | **TB** | **B** | **AB** | **P** | **NS** | **TB** | **B** | **AB** | **P** | **NS** | **TB** | **B** | **AB** | **P** | **NS** |
| **Français** | **X** | | | | | | **X** | | | | | **X** | | | | | | **X** | | |

| | | | | | | | | | | | | | | | | | | | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| **Anglais** | | | **X** | | | | **X** | | | | | **X** | | | | | | **X** | | |

Grille d'évaluation :

- **TB :** Très bien
- **B :** Bien
- **AB :** Assez bien
- **P :** Passable
- **NS :** Niveau scolaire

**CENTRE D'INTERET**

**Sport :** Yoga

**Loisir et divertissement :** Séries, voyage, pâtisserie

# Sommaire

**Curriculum Vitae**.....I

**Sommaire** .....IV

**Remerciements**.....VII

**Liste des figures** ..... VIII

**Listes des tableaux**.....IX

**Listes des abréviations** ..... X

**Introduction générale**..... 1

**Partie I : PRESENTATIONS** ..... 2

Chapitre 1 : Présentation de l'ENI ..... 3

1.1. Information d'ordre générale ..... 3

1.2. Missions et historiques..... 3

1.3. Organigramme institutionnel..... 5

1.4. Domaine de spécialisation..... 6

1.5. Architecture des formations pédagogiques ..... 7

1.6. Relation de l'ENI avec les organismes externes ..... 9

1.7. Débouchés professionnels et diplômés ..... 9

1.8. Ressources humaines..... 12

Chapitre 2: Présentation de l'établissement d'accueil..... 13

**2.1. Description et statuts :** ..... 13

**2.2. Activités**..... 14

**2.3. Contacts et adresses**..... 15

**2.4. Nos partenaires**..... 15

**2.5. Organigramme** ..... 16

Chapitre 3 : Description du projet..... 17

**3.1. Formulation** ..... 17

**3.2. Objectif et besoins de l'utilisateur** ..... 17
**3.3. Moyens nécessaires à la réalisation du projet (Humain, Matériel, Logiciel)** 18
**3.4. Résultats attendus** ..... 18
**3.5. Chronogramme de travail** ..... 19
**PARTIE II : ANALYSE ET CONCEPTION** ..... 20
Chapitre 4 : Analyse préalable ..... 21
4.1. Analyse de l'existant ..... 21
4.2. Critique de l'existant (points forts et points faibles) ..... 25
4.3. Proposition de solutions ..... 26
Chapitre 5 : Modèle et architecture de l'IoT ..... 29
5.1. Cadre conceptuel et fondements du modèle IoT ..... 29
5.2. Conception et rôle de la couche perception (capteurs et dispositifs) ..... 29
5.3. Technologies de connectivité et protocoles de transmission dans la couche réseau 29
5.4. Modélisation schématique d'une architecture IoT appliquée ..... 30
5.5. Analyse comparative des modèles de référence normalisés ..... 31
5.6. Limites techniques et défis d'ingénierie de l'architecture IoT ..... 32
Chapitre 6 : Études et choix des outils ..... 33
6.1. Outils utilisés ..... 33
6.2. Données et stratégie d'amorçage à froid ..... 37
**PARTIE III : RÉALISATION** ..... 43
Chapitre 7 : Présentation de l'environnement ..... 44
7.1. Prototype de maison intelligente ..... 44
7.2. Plateforme d'attaque ..... 45
7.3. Présentation de Mysa ..... 45
Chapitre 8 : Installation et configuration ..... 48
8.1. Broker MQTT sécurisé ..... 48

8.2. Segmentation réseau en VLAN ..... 51
8.3. Firmware des nœuds ESP32 ..... 52
8.4. Ingestion MQTT et stockage ..... 55
8.5. Moteur de détection comportementale ..... 56
8.6. Modèles de référence et amorçage à froid ..... 58
8.7. API de consultation ..... 59
8.8. Dashboard de supervision ..... 60
8.9. Simulateur d'attaque (à réaliser) ..... 62
Chapitre 9 : Test et validation ..... 66
9.1. Protocole et mesures ..... 66
9.2. Tests d'intrusion ..... 66
9.3. Évaluation de la détection comportementale ..... 67
9.4. Évaluation hors ligne des modèles de référence ..... 67
9.5. Discussion et limites ..... 67
**Conclusion** ..... 70
**Références bibliographiques** ..... XIII
**Références webographiques** ..... XV
**Glossaire** ..... XVI
**Annexes** ..... XVIII
**Tables des matières** ..... XIX
**Résumé** ..... XXIV
**Abstract** ..... XXIV

# Remerciements

Au terme de ce travail, je tiens à exprimer ma sincère reconnaissance envers toutes les personnes qui ont contribué, de près ou de loin, à la réalisation de ce mémoire.

- Monsieur, **HAJALALAINA** Aimé Richard, Professeur, Président de l'Université de Fianarantsoa, pour avoir permis la tenue de cette formation de haut niveau au sein de l'établissement.
- Monsieur **MAHATODY** Thomas, Professeur, Directeur de l'Ecole Nationale d'Informatique, pour la qualité de l'encadrement administratif et pédagogique offert tout au long du cursus.
- Monsieur **RAFANDROANA** Patrice Mahenina, Directeur de la société UN-IT, pour m'avoir accueilli en stage et pour la confiance accordée dans la conduite de ce projet.
- Monsieur **DIMBISOA** William Germain, Maître de Conférences, Responsable de la mention Intelligence Artificielle, pour le suivi assuré durant toute l'année universitaire.
- Monsieur **GILANTE** Gesazafy, Assistant d'Enseignement Supérieur et de Recherche, Responsable du parcours Objets Connectés et Cybersécurité, pour les orientations apportées sur le contenu technique du mémoire.
- Madame/Monsieur [Nom et Prénoms], Président du jury, pour l'honneur fait d'évaluer ce travail.
- Madame/Monsieur [Nom et Prénoms], Examinateur, pour le temps consacré à la lecture et à la critique constructive de ce mémoire.
- Madame **RATIANANTITRA** Volatiana Marielle, Maître de Conférences, Encadreur pédagogique, pour la disponibilité, les conseils méthodologiques et le suivi régulier apporté pendant toute la durée du projet.
- Monsieur **ANDRIANTSIALO** Elyah Frisco, Co-directeur de la société UN-IT, Encadreur professionnel, pour l'accompagnement technique et les retours apportés sur la réalisation du prototype.
- Ma famille et mes amis, pour leur soutien moral constant tout au long de ce parcours.

# Liste des figures

Figure 1 : Organigramme de l'Ecole Nationale d'Informatique ..... 6
Figure 2 : Architecture des études correspondant au système LMD ..... 8
Figure 3 : Organigramme de l'UN-IT ..... 16
Figure 4 : Chronogramme de travail ..... 19
Figure 5 : Architecture en couches de Mysa ..... 30
Figure 6 : Segmentation du prototype en quatre VLAN ..... 31
Figure 7 : Photographie du montage des deux nœuds ESP32 ..... 44
Figure 8 : Capture des messages MQTT reçus par le broker pour chaque appareil ..... 44
Figure 9 : Flux de données de Mysa ..... 46
Figure 10 : Capture des tests de refus et de succès de connexion ..... 50
Figure 11 : Topologie GNS3 avec les quatre VLAN ..... 52
Figure 12 : Schéma de câblage des deux nœuds ..... 55
Figure 13 : Capture du vérification effectué sur le prototype ..... 57
Figure 14 : capture de /docs ..... 59
Figure 15 : Capture du Dashboard ..... 62
Figure 16 : Capture d'une exécution de l'orchestrateur ..... 65
Figure 17 : Résultat d'un scan nmap depuis la machine Kali (TI-04) ..... 66
Figure 18 : Alerte affichée sur le dashboard lors du scénario SC-01 ..... 67

# Listes des tableaux

Tableau 1 : Connaissance lunguistiques ..... II
Tableau 2: Organisation du système de formation pédagogique de l'Ecole ..... 6
Tableau 3: Mention et parcours au sein de l'ENI ..... 7
Tableau 4: Liste des formations existantes à l'ENI ..... 8
Tableau 5: Débouchés éventuels des jeunes diplômés ..... 10
Tableau 6 : Grille de criticité (impact en lignes, probabilité en colonnes) ..... 22
Tableau 7 : Vulnérabilités identifiées ..... 22
Tableau 8 : Evaluation des risques ..... 23
Tableau 9 : Cartographie des composants et criticité ..... 24
Tableau 10 : Points forts et points faibles de l'existant ..... 25
Tableau 11 : Comparaison des deux solutions ..... 27
Tableau 12 : Positionnement de Mysa par rapport aux modèles de référence ..... 31
Tableau 13 : Alternatives pour le firmware ESP32 ..... 33
Tableau 14 : Comparaison de MQTT, CoAP et HTTP/REST ..... 34
Tableau 15 : Alternatives pour le stockage ..... 35
Tableau 16 : Jeux de télémétrie TON_IoT et catégories Mysa associées ..... 37
Tableau 17 : Les trois régimes de fonctionnement d'un flux ..... 39
Tableau 18 : Association entre nom de capteur et catégorie ..... 40
Tableau 19 : **Caractéristiques d'une fenêtre de 20 messages** ..... 40
Tableau 20 : Synthèse des outils retenus ..... 42
Tableau 21 : Appareils du prototype ..... 44
Tableau 22 : Blocs logiciels de Mysa et fichiers correspondants ..... 45
Tableau 23 : Points d'accès de l'API ..... 46
Tableau 24 : Tests de vérification du broker ..... 50
Tableau 25 : Plan de segmentation ..... 51
Tableau 26 : Tables SQLite ..... 55
Tableau 27 : Paramètres du moteur ..... 57
Tableau 28 : Tests d'intrusion ..... 62
Tableau 29 : Scénarios comportementaux ..... 63
Tableau 30 : Résultats des tests d'intrusion ..... 66
Tableau 31 : Détection comportementale par configuration ..... 67
Tableau 32 : Métriques des modèles de référence sur TON_IoT ..... 67
Tableau 33 : Séparation normal/attaque par caractéristique ..... 68
Tableau 34 : Cadence des lignes, fenêtres normales et d'attaque ..... 68

# Listes des abréviations

ACL : Access Control List

API : Application Programming Interface

AUC : Area Under the Curve (aire sous la courbe ROC)

CA : Certificate Authority (autorité de certification)

CHR : Cloud Hosted Router

CLI : Command Line Interface

CPU : Central Processing Unit

CSV : Comma-Separated Values

DDoS : Distributed Denial of Service

DHCP : Dynamic Host Configuration Protocol

DHT22 : Digital Humidity and Temperature sensor (modèle 22)

DNS : Domain Name System

DoS : Denial of Service

EBIOS RM : Expression des Besoins et Identification des Objectifs de Sécurité – Risk Manager

ENI : Ecole Nationale d'Informatique

ESN : Entreprise de Services Numériques

ESP32 : Espressif Systems 32-bit microcontroller

GNS3 : Graphical Network Simulator-3

GPIO : General Purpose Input/Output

HTTP : HyperText Transfer Protocol

HTTPS : HyperText Transfer Protocol Secure

IA : Intelligence Artificielle

IDS : Intrusion Detection System

IIoT : Industrial Internet of Things

IoT : Internet of Things

IPS : Intrusion Prevention System

ISO : International Organization for Standardization

ITU-T : International Telecommunication Union – Telecommunication Standardization Sector

JSON : JavaScript Object Notation

LAN : Local Area Network

LED : Light Emitting Diode

LMD : Licence-Master-Doctorat

M2 : Master 2

ML : Machine Learning

MQTT : Message Queuing Telemetry Transport

NIST : National Institute of Standards and Technology

OCC : Objets Connectés et Cybersécurité

OS : Operating System

PIR : Passive InfraRed (capteur de mouvement)

QEMU : Quick EMUlator

RAM : Random Access Memory

REST : Representational State Transfer

RFID : Radio Frequency IDentification

SaaS : Software as a Service

SARL : Société à Responsabilité Limitée

SQL : Structured Query Language

SSH : Secure SHell

TCP/IP : Transmission Control Protocol / Internet Protocol

TLS : Transport Layer Security

UART : Universal Asynchronous Receiver-Transmitter

UDP : User Datagram Protocol

UI : User Interface

UX : User Experience

VLAN : Virtual Local Area Network

VM : Virtual Machine

WAN : Wide Area Network

Wi-Fi : Wireless Fidelity

# Introduction générale

La généralisation des objets connectés transforme en profondeur l'habitat domestique : ampoules, caméras, thermostats, serrures et capteurs divers communiquent en permanence sur le réseau local pour offrir confort et automatisation. Cette multiplication des points de connexion élargit considérablement la surface d'exposition des foyers aux menaces informatiques, dans un contexte où les utilisateurs disposent rarement des compétences nécessaires pour superviser eux-mêmes la sécurité de leur réseau.

Les mécanismes de sécurité classiques, fondés sur la reconnaissance de signatures d'attaques connues, atteignent rapidement leurs limites face à la diversité des objets connectés domestiques et à l'apparition régulière de nouvelles menaces. Se pose alors la problématique centrale de ce travail : comment détecter, au sein d'un réseau domestique hétérogène, des comportements anormaux d'appareils connectés sans dépendre d'une connaissance préalable de la menace exacte ?

Le présent mémoire a pour objectif de développer le thème suivant : « Mysa : une architecture autonome de cybersécurité comportementale pour les écosystèmes de maisons intelligentes ». Pour y parvenir, l'approche méthodologique adoptée combine une conception architecturale en couches inspirée des modèles de référence de l'IoT, un prototypage matériel et logiciel associant appareils physiques et simulés, puis une validation empirique au moyen de scénarios d'attaque automatisés permettant de mesurer la capacité de détection du système.

Ce mémoire s'articule en trois parties. La Partie I présente le cadre général du projet : l'établissement pédagogique, l’établissement d'accueil et la description du projet Mysa. La Partie II développe l'analyse préalable, l'architecture IoT retenue et les outils choisis pour la conception. La Partie III est consacrée à la réalisation du prototype, à son installation et à sa configuration, ainsi qu'aux tests de validation permettant d'évaluer la pertinence de l'approche comportementale proposée.

# Partie I : PRESENTATIONS

Cette première partie pose le cadre général du projet. Elle présente l'École Nationale d'Informatique, établissement de formation dans lequel s'inscrit ce mémoire, puis UN-IT, l'établissement d'accueil. Elle décrit enfin le projet Mysa : sa problématique, ses objectifs, ses besoins, ses moyens et son planning.

# Chapitre 1 : Présentation de l'ENI

L'École Nationale d'Informatique (ENI) est reconnue comme un établissement de référence à Madagascar dans le domaine de la formation en informatique.

## 1.1. Information d'ordre générale

L'Ecole Nationale d'Informatique, en abrégé ENI, est un établissement d'enseignement supérieur rattaché académiquement et administrativement à l'Université de Fianarantsoa. Le siège de l'Ecole se trouve à Tanambao-Antaninarenina à Fianarantsoa. L'adresse pour la prise de contact avec l'Ecole est la suivante : Ecole Nationale d'Informatique (ENI) Tanambao, Fianarantsoa. Le numéro de sa boîte postale est 1487 avec le code postal 301. Téléphone : 038 96 566 96 ou 034 76 591 95. Son adresse électronique est la suivante : **eni@eni.mg**. Il dispose également d'un site web : **www.eni.mg**

## 1.2. Missions et historiques

L'ENI se positionne sur l'échiquier socio-éducatif malgache comme étant le plus puissant secteur de diffusion et de vulgarisation des connaissances et des technologies informatiques.

Cette Ecole Supérieure peut être considérée aujourd'hui comme la vitrine et la pépinière des élites informaticiennes du pays.

De façon formelle, l'ENI était créée par le décret N° 83- 185 du 24 Mai 1983, comme étant le seul établissement Universitaire Professionnalisé au niveau national, destiné à former des techniciens et des Ingénieurs de haut niveau, aptes à répondre aux besoins et exigences d'Informatisation des entreprises, des sociétés et des organes implantés à Madagascar.

L'ENI a pour conséquent pour mission de former des spécialistes informaticiens compétents et opérationnels de différents niveaux notamment :

- En fournissant à des étudiants des connaissances de base en informatique ;
- En leur transmettant le savoir-faire requis, à travers la professionnalisation des formations dispensées et en essayant une meilleure adéquation des formations par rapport aux besoins évolutifs des sociétés et des entreprises ;
- En initiant les étudiants aux activités de recherche dans les différents domaines des Technologies de l'Information et de la Communication (TIC) ;

La filière de formation d'Analystes Programmeurs a été mise en place à l'Ecole en 1983, et a été gelée par la suite en 1996, tandis que la filière de formation d'ingénieurs a été ouverte à l'Ecole en 1986.

Une formation de troisième cycle a été ouverte à l'Ecole a été ouverte à l'Ecole depuis l'année 2003 – 2004 grâce à la coopération académique et scientifique entre l'Université de Fianarantsoa pour le compte de l'ENI et l'Université Paul Sabatier de Toulouse (UPST).

Cette filière avait pour objectif de former certains étudiants à la recherche dans les différents domaines de l'Informatique, et notamment pour préparer la relève des Enseignants-Chercheurs qui étaient en poste.

Pendant l'année 2007-2008, la formation en vue de l'obtention du diplôme de Licence Professionnelle en Informatique a été mise en place à l'ENI avec les deux parcours de formation :

- Génie Logiciel et base de Données.
- Administration des Système et réseaux.

La mise en place à l'Ecole de ces deux options de formation devait répondre au besoin de basculement vers le système Licence – Master – Doctorat (LMD).

En vue de surmonter les difficultés de limitation de l'effectif des étudiants accueillis à l'Ecole, notamment à cause du manque d'infrastructures, un système de « Formation Hybride » a été mise en place à partir de l'année 2010. Il s'agit en effet d'un système de formation semi présentielle et à distance avec l'utilisation de la visioconférence pour la formation à distance. Le système de formation hybride a été ainsi créé à Fianarantsoa ainsi qu'Université de Toliara. Cette formation est à l'origine du parcours Informatique Générale.

En 2023, la mention Intelligence Artificielle (IA) a été ouvert au sein de l'Ecole pour répondre les besoins des entreprises. La formation est destinée aux étudiants titulaires du diplôme de licence (Bac +3) en Mathématiques ou en Statistiques ou en Informatique, etc.

La mention IA comporte deux parcours :

- Gouvernance et Ingénierie de Données (GID),
- Objets connectés et Cybersécurité (OCC).

Le principe de l'enseignement pour le parcours GID offre aux l'étudiants des compétences scientifiques et techniques spécialisées en Science de données. Pour le parcours OCC, les étudiants octroient la double spécialité premièrement en internet des objets et deuxièmement en cybersécurité. La formation de master est axée sur l'ensemble d'applications de l'Intelligence Artificielle.

Depuis l'année universitaire 2024-2025, la mention Expertise Digitale est officiellement ouverte au grand public. Cette mention propose deux (2) parcours distincts :

- Métiers du Digital (MDi) – disponible aux niveaux Licence et Master. Ce parcours est destiné aux étudiants titulaires du diplôme de Baccalauréat, toutes séries confondues. Il est élaboré pour équiper les étudiants des compétences essentielles dans les domaines du marketing digital, de la communication digitale, et de la gestion de projets digitaux.
- Audit des Systèmes d'Information (ASI) – proposé au niveau Master uniquement. Ce parcours s'adresse aux étudiants titulaires d'une licence (Bac +3) en Mathématiques, en Statistiques ou en Informatique. Il est structuré pour approfondir les connaissances théoriques et pratiques nécessaires à l'audit efficace des systèmes d'information.

Le système d'enseignement adopté pour cette mention est un système en ligne. Ainsi, les cours et ressources pédagogiques sont accessibles en permanence via la plateforme numérique Moodle. Par ailleurs, des regroupements en présentiel ou en ligne seront organisés périodiquement, conformément au planning défini par les responsables pédagogiques.

À partir de l'année universitaire 2026, dans le cadre de la réorganisation de l'offre de formation, les anciens parcours de la Mention Informatique ont été restructurés et renommés afin de mieux refléter l'évolution des domaines et des compétences visés. Ainsi, l'ancien parcours Génie Logiciel et Base de Données (GB) devient le parcours Ingénierie Logicielle et Systèmes d'Information (ILSI), le parcours Administration des Systèmes et Réseaux (ASR) devient Ingénierie des Systèmes et Réseaux Informatiques (ISRI), tandis que le parcours Informatique Générale (IG) devient Ingénierie des Systèmes d'Information Intégrés (ISII). Cette évolution vise notamment à actualiser les intitulés et à renforcer la cohérence entre les formations proposées et les besoins actuels du secteur numérique.

### 1.3. Organigramme institutionnel

L'organigramme de l'Ecole est inspiré des dispositions du décret N° 83-185 du 24 Mai 1983. L'ENI est administrée par un Conseil d'Ecole, et dirigée par un directeur nommé par un décret adopté en Conseil des Ministres. Le Collège des enseignants regroupant tous les enseignants-chercheurs permanents de l'Ecole est chargé de résoudre les problèmes liés à l'organisation pédagogique des enseignements. Le Conseil Scientifique propose les orientations pédagogiques et scientifiques de l'établissement, en tenant compte notamment de l'évolution du marché de travail et de l'adéquation des formations dispensées par rapport aux besoins des entreprises.

La figure 1 représente l'organigramme actuel de l'Ecole Nationale d'Informatique.

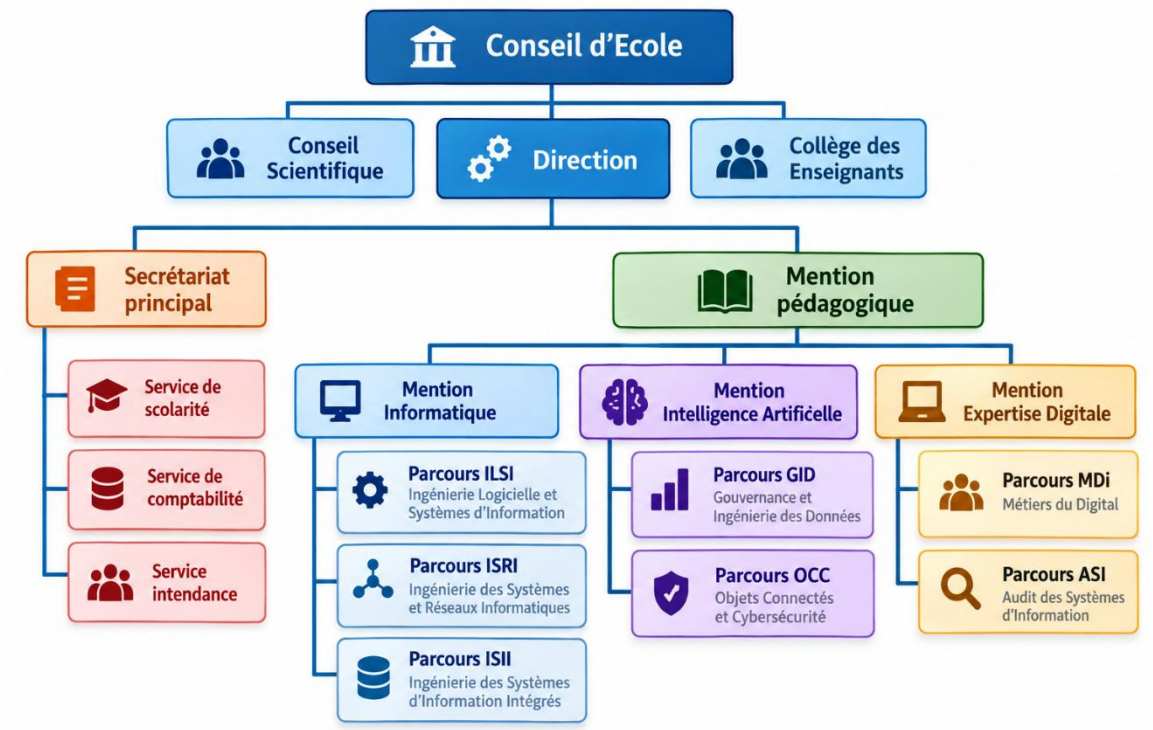



Figure 1 : Organigramme de l'Ecole Nationale d'Informatique

1.4. Domaine de spécialisation

Les activités de formation et de recherche organisées à l'ENI portent sur les domaines suivants :

- Ingénierie logicielle et systèmes d'information
- Ingénierie des systèmes et réseaux informatiques
- Ingénierie des systèmes d'information intégrés
- Gouvernance et ingénierie des données
- Objets connectés et cybersécurité
- Métiers du digital et transformation numérique
- Audit des systèmes d'information
- Intelligence artificielle et ses applications.
- Modélisation informatique et mathématique des Systèmes complexes ;

Le tableau 2 décrit l'organisation du système de formation pédagogique de l'Ecole.

Tableau 2: Organisation du système de formation pédagogique de l'Ecole

| Formation Théorique | Formation Pratique |
|---|---|
| – Enseignement théorique<br>– Travaux dirigés<br>– Travaux pratiques<br>– Conférences | – Etude de cas<br>– Travaux de réalisation<br>– Projets/ Projets tutorés<br>– Voyages d'Etudes<br>– Stages en entreprise |

1.5. Architecture des formations pédagogiques

Le recrutement des étudiants à l'ENI se fait uniquement par voie de concours d'envergure nationale en première année. Les offres de formation organisées à l'Ecole ont été validées par la Commission Nationale d'Habilitation (CNH). Au sein de l'ENI, il existe trois mentions et sept parcours. Le tableau 2 récapitule les mentions et les parcours au sein de l'Ecole :

Tableau 3: Mention et parcours au sein de l'ENI

| **Mention** | **Parcours** |
|---|---|
| **Informatique** | Ingénierie logicielle et systèmes d'information (ILSI) |
| | Ingénierie des systèmes et réseaux informatiques (ISRI) |
| | Ingénierie des systèmes d'information intégrés (ISII) |
| **Intelligence Artificielle** | Gouvernance et Ingénierie de Données (GID) |
| | Objets Connectés et Cyber sécurités (OCC) |
| **Expertise Digitale** | Métiers du Digital (MDi) |
| | Audit des Systèmes d'Information (ASI) |

La figure 2 représente l'architecture des études correspondant au système LMD.

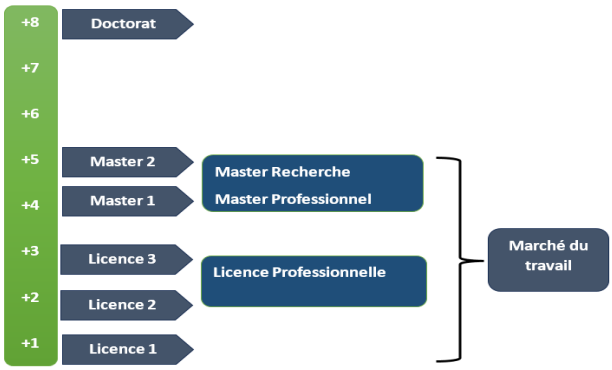



Figure 2 : Architecture des études correspondant au système LMD

La licence peut avoir une vocation générale ou professionnelle. Le master peut avoir une vocation professionnelle ou de recherche. L'accès en première année de MASTER se fait automatiquement pour les étudiants de l'Ecole qui ont obtenu le diplôme de Licence Professionnelle.

Le tableau 4 illustre la liste des formations existantes à l'ENI.

Tableau 4: Liste des formations existantes à l'ENI

| | FORMATION | |
|---|---|---|
| | LICENCE PROFESSIONNELLE | MASTER |
| Condition admission | Par voie de concours | Par voie de concours pour la mention IA |
| Condition d'accès | Bac de série C, D ou Technique | Être titulaire de licenceprofessionnelle |
| Durée de Formation | 3 ans | 2 ans |
| Diplôme délivré | Diplôme de Licence Professionnelle | Diplôme de Master Professionnel<br>Diplôme de Master Recherche |

Le Master Recherche permet à son titulaire de poursuivre directement des études en doctorat et de s'inscrire directement dans une Ecole Doctorale.

Les étudiants diplômés de l'Ecole sont plutôt bien accueillis dans les instituts universitaires étrangères (Canada, Suisse, France, …)

### 1.6. Relation de l'ENI avec les organismes externes

Les stages effectués chaque année par les étudiants mettent l'Ecole en rapport permanent avec plus de 400 entreprises et organismes publics, semi-publics et privés, nationaux et internationaux. L'Ecole dispose ainsi d'un réseau d'entreprises, de sociétés et d'organismes publics et privés qui sont des partenaires par l'accueil en stage de ses étudiants, et éventuellement pour le recrutement après l'obtention des diplômes par ces derniers. Les compétences que l'Ecole cherche à développer chez ses étudiants sont l'adaptabilité, le sens de la responsabilité, du travail en équipe, le goût de l'expérimentation et l'innovation.

En effet, la vocation de l'ENI est de former des licenciés et des ingénieurs de niveau MASTER avec des qualités scientifiques, techniques et humaines reconnues, capables d'évoluer professionnellement dans des secteurs d'activité variés intégrant l'informatique. Les stages en milieu professionnel permettent de favoriser une meilleure adéquation entre les formations à l'Ecole et les besoins évolutifs du marché de l'emploi.

Parmi les sociétés, les entreprises et les organismes partenaires de l'Ecole, on peut citer : ACCENTURE Mauritius, AKATA Goavana, Air Madagascar, Ambre Associates, Airtel, Agence Universitaire de la Francophonie (AUF), AXIAN, B2B, Banque Centrale, , BIANCO, BlueLine, CNaPS, Bureau National de Gestion des Risques et des Catastrophes (BNGRC), CEDII-Fianarantsoa, Data Consulting, Central Test, Centre National Antiacridien, CNRE, COLAS, Direction Générale des Douanes, DLC, E-Tech Consulting, , FID, FIHARY Soft, FTM, GNOSYS, GENIUS AT WORK, Hello Tana, IBONIA, INGENOSIA, INSTAT, IOGA, JIRAMA, JOUVE, MADADEV, MAEP, MANAO, MEF, MEN, MESupRES, MFB, , MININTER, Min des Postes/Télécommunications et du Développement Numérique, NEOV MAD, Ny Havana, Madagascar National Parks, OMNITEC, ORANGE, OTME, PRACCESS, QMM Fort-Dauphin, SG Madagasikara SMMC, SMMEC, SNEDADRS Antsirabe, Sénat, Société d'Exploitation du Port de Toamasina (SEPT), SOFTWELL, Strategy Consulting, TELMA, VIVETEC, Société LAZAN'I BETSILEO, WWF, UGD, ARATO, MANAO, MNDPT, NG ACADEMY.NG, Relia, Spoon Consulting …

### 1.7. Débouchés professionnels et diplômés

Les formations proposées par l'Ecole permettent aux diplômés d'être immédiatement opérationnels sur le marché du travail avec la connaissance d'un métier complet lié à l'informatique aux TIC.

L'Ecole apporte à ses étudiants un savoir-faire et un savoir-être qui les accompagnent tout au long de leur vie professionnelle. Elle a une vocation professionnalisante. Les diplômés en LICENCE et en MASTER issus de l'ENI peuvent faire carrière dans différents secteurs.

L'Ecole bénéficie aujourd'hui de 40 années d'expériences pédagogiques et de reconnaissance auprès des sociétés, des entreprises et des organismes. C'est une Ecole Supérieure de référence en matière informatique.

D'une manière générale, les diplômés de l'ENI n'éprouvent pas de difficultés particulières à être recrutés au terme de leurs études. Cependant, l'ENI recommande à ses diplômés de promouvoir l'entrepreneuriat en TIC et de créer des cybercafés, des SSII ou des bureaux d'études.

Le tableau 5 représente les débouchés éventuels selon la mention.

Tableau 5: Débouchés éventuels des jeunes diplômés

| **Mention** | **Débouchés professionnels** |
|---|---|
| INFORMATIQUE | ILSI : Développeur logiciel / développeur full-stack, Ingénieur en développement d'applications (desktop, web, mobile), Architecte logiciel, Intégrateur d'applications, Développeur d'API, Administrateur de bases de données (DBA), Ingénieur en conception de bases de données, Développeur SQL / PL-SQL, Spécialiste en migration et optimisation de bases de données, Data engineer (ingénieur en traitement de données), Analyste programmeur, Analyste fonctionnel, Chef de projet informatique, Scrum master / Product owner (en méthodologie Agile), Ingénieur QA (Quality Assurance), Testeur logiciel / testeur automatisé, Spécialiste maintenance applicative, Expert en refactoring et optimisation de code, Analyste de données (Data analyst), Concepteur d'outils décisionnels (BI), Ingénieur en Big Data, Machine Learning Engineer, Consultant fonctionnel ou freelance<br><br>ISRI : Administrateur systèmes et réseaux, Ingénieur systèmes et réseaux, Administrateur systèmes Linux / Windows, Administrateur cloud (AWS, Azure, Google Cloud), Ingénieur virtualisation (VMware, Hyper-V, |

| | |
|---|---|
| | Proxmox), Administrateur sécurité (Security Administrator), Ingénieur cybersécurité, Analyste SOC (Security Operations Center), Spécialiste firewall / VPN, Responsable sécurité informatique (RSSI – avec expérience), Technicien support informatique (N2/N3), Technicien réseaux et télécoms, Ingénieur exploitation, Administrateur messagerie (Exchange, Microsoft 365), Technicien datacenter, Architecte réseaux, Architecte systèmes, Consultant infrastructure, Chef de projet systèmes et réseaux, Ingénieur DevOps, Administrateur Kubernetes / Docker, Cloud engineer, Spécialiste automatisation (Ansible, Terraform)<br><br>ISII : ILSI et ISRI en même temps |
| INTELLIGENCE ARTIFICIELLE | GID : Développeur IA, Data Scientist, Entrepreneur IA, Consultant IA, Responsable marketing IA, Business Developer IA, Product Owner, Consultant en cybersécurité, Directeur de l'Innovation ;<br>OCC : Analyste en cybersécurité, Ingénieur en cybersécurité, Spécialiste en réponse aux incidents, Architecte de sécurité, Consultant en cybersécurité, Auditeur en cybersécurité, Expert en sécurité des données, Responsable de la sécurité des informations, Chercheur en cybersécurité, Formateur en cybersécurité, Ingénieur IoT, Développeur IoT, Architecte IoT, Spécialiste en sécurité IoT, Analyste de données |
| EXPERTISE DIGITALE | MDi : Spécialiste en Marketing Digital, Gestionnaire de Contenu Web, Analyste UX/UI, Product Owner, Chef de Projet Digital, Stratège en Médias Sociaux, Analyste de Performance Digitale, Chef de Projet Digital, Stratège en Médias Sociaux, Concepteur-Rédacteur Web Analyste de Performance Digitale, Expert en Commerce Électronique, Expert en Commerce Électronique, Spécialiste SEO/SEM, Manager de Communauté (Community Manager), Conseiller en Stratégie Digitale, Responsable CRM (Customer Relationship Management), Spécialiste en Analytique et Intelligence d'Affaires (Business Intelligence), Consultant en Transformation Digitale, Responsable des Partenariats Digitaux, Spécialiste en Cybersécurité Marketing, Directeur de l'Innovation Digitale, Manager de l'E-réputation |

| | |
|---|---|
| | ASI : Auditeur des Systèmes d'Information, Consultant en Sécurité des Systèmes d'Information, Analyste de Risques IT, Chef de Projet SI, Responsable de la Conformité IT, Spécialiste en Cyber Forensics, Directeur de l'Audit et de la Sécurité des Systèmes d'Information, Expert en Gouvernance IT, Formateur ou Éducateur en Sécurité des Chercheur en Sécurité IT |

1.8. Ressources humaines

Les ressources humaines sont citées ci-dessous selon leurs responsabilités :

- Directeur de l'Ecole : Monsieur MAHATODY Thomas, Professeur
- Responsable de la Mention « Informatique » : Monsieur RALAIVAO Jean Christian, Maître de Conférences
- Responsable de la Mention « Intelligence Artificielle » : Monsieur DIMBISOA William Germain, Maître de Conférences
- Responsable de parcours « ILSI » : Madame RATIANANTITRA Volatiana Marielle, Maître de Conférences
- Responsable de parcours « ISRI » : Monsieur RAZAFINDRAIBE Marolahy Alix, Assistant d'Enseignement Supérieur et de Recherche
- Responsable de parcours « ISII » : Monsieur RAZAFINDRAMONJA Clément Aubert, Assistant d'Enseignement Supérieur et de Recherche
- Responsable de parcours « GID » : Madame RAKOTOASIMBAHOAKA Antsa Cyprienna, Maître de Conférences
- Responsable de parcours « OCC » : Monsieur GILANTE Gesazafy, Assistant d'Enseignement Supérieur et de Recherche

L'ENI compte seize (16) enseignants permanents dont un (01) Professeur Titulaire, deux (02) Professeurs, Neuf (09) Maîtres de Conférences, Quatre (04) Assistants d'Enseignement Supérieur et de Recherche, plusieurs enseignants vacataires et personnel administratif.

# Chapitre 2 : Présentation de l'établissement d'accueil

Ce chapitre présente UN-IT, l'entreprise de services numériques qui a accueilli la réalisation de ce projet. Il décrit son statut et sa vision, ses activités, ses coordonnées et ses partenaires, puis son organisation interne à travers son organigramme.

## 2.1. Description et statuts :

UN-IT, entreprise de services numériques (ESN), a été fondée en 2022 par un groupe d'ingénieurs passionnés issus de l'ENI et de l'EMIT de l'Université de Fianarantsoa. Leur ambition ? Transformer les idées en solutions numériques sur mesure tout en stimulant le développement industriel et socioéconomique de Madagascar.

Depuis le 15 mars 2025, UN-IT s'est officiellement constituée en Société à Responsabilité Limitée (SARL), sous la direction de RAFANDROANA Patrice Mahenina et ANDRIANTSIALO Elyah Frisco. Cette étape clé ancre notre engagement et structure notre croissance pour mieux servir nos clients et nos ambitions.

Grâce à une expertise technologique reconnue et une approche centrée sur l'humain, UN-IT conçoit des solutions innovantes pour permettre aux entreprises et aux particuliers d'accroître leur visibilité, leur compétitivité et leur rentabilité.

**Sa vision :**

Devenir un partenaire de confiance pour les entreprises malgaches et internationales en proposant des solutions numériques de pointe, entièrement adaptées à leurs besoins spécifiques.

Convaincue que la transformation digitale est un levier essentiel de croissance, UN-IT s'engage à :

- Fournir des solutions technologiques performantes et durables.
- Stimuler l'emploi local en accompagnant les jeunes talents dans leur développement.
- Soutenir les entreprises dans leur transition numérique pour créer un impact positif et durable.

UN-IT, c'est l'alliance entre innovation, expertise et responsabilité sociale, au service de la croissance des entreprises et du développement de Madagascar. 12

### 2.2. Activités

UN-IT est une entreprise qui propose une gamme variée de services pour aider les entreprises et les particuliers à atteindre leurs objectifs mais son activité principale est la création de logiciels personnalisés, d'applications web ou mobiles et de sites web pour répondre aux besoins de chaque client.

Les principales activités et service de UN-IT sont les suivant :

- **Conception UI/UX :** Nous plaçons l'utilisateur au centre de la conception, avec des interfaces intuitives et engageantes basées sur des recherches approfondies et des profils utilisateurs détaillés.
- **Développement Web :** De sites e-commerce dynamiques à des blogs personnalisés, nous développons des solutions web sur-mesure qui répondent à vos objectifs commerciaux
- **Développement Mobile :** Des applications multiplateformes optimisées pour iOS et Android, offrant une expérience fluide et cohérente sur tous les appareils.
- **Solutions d'Intelligence Artificielle :** Automatisation, personnalisation et optimisation : nous intégrons l'IA pour transformer vos processus métiers et offrir des solutions innovantes.
- **Transformation Digitale :** Accompagnement stratégique pour optimiser vos processus et adopter les dernières technologies, afin de rester compétitif dans un monde numérique en évolution rapide.
- **Maintenance Logicielle :** Une surveillance proactive pour garantir la performance et la stabilité de vos logiciels à long terme.

Nous accompagnons entreprises et particuliers dans leur transformation digitale à travers :

- La création d'applications web, mobiles et desktop sur mesure.
- La conception et la mise en ligne de sites internet modernes.
- L'intégration de solutions d'intelligence artificielle (API, automatisation, modèles IA personnalisés).
- La digitalisation des processus métiers.

- La maintenance corrective et évolutive de sites et applications
- Formations

Nous développons les compétences numériques de vos équipes et du grand public grâce à des formations adaptées :

- Formations professionnelles pour les entreprises (bureautique, productivité, IA appliquée, outils digitaux).
- Formations pratiques pour les particuliers (développement web, initiation aux technologies, etc.).
- Solutions SaaS

Nous mettons à disposition des solutions logicielles prêtes à l'emploi (Software as a Service) pour simplifier la gestion de vos activités :

### 2.3. Contacts et adresses

Actuellement le siège de UN-IT se trouve à Antamponjina Fianarantsoa Lot 0303X/0012B Antamponjina Fianarantsoa.

- Contact : +261349303552
- Courriel : contact@unityfianar.site
- Site web : www.unityfianar.site

### 2.4. Nos partenaires

Chez UN-IT, nous collaborons avec des partenaires de confiance pour offrir des solutions numériques innovantes et enrichir notre impact social et éducatif :

- ARATO : Spécialiste de la transformation numérique, ARATO nous soutient dans le développement de technologies avancées et l'intégration de solutions digitales adaptées aux besoins des entreprises.
- Kajy University : Institution académique reconnue, Kajy University forme les talents de demain en ingénierie informatique et en technologies émergentes, partageant avec nous une vision commune d'innovation et de croissance.
- CERES : Programme éducatif d'excellence créé en 2006 à Fianarantsoa, CERES (Centres de Renforcement Educatif et Scolaire) favorise l'accès à une éducation de qualité pour les collégiens ruraux défavorisés de la région Haute-Matsiatra. En

soutenant ces jeunes – dont 50 % de filles – CERES contribue à leur réussite scolaire, leur insertion professionnelle et leur engagement pour le développement de Madagascar.

### 2.5. Organigramme

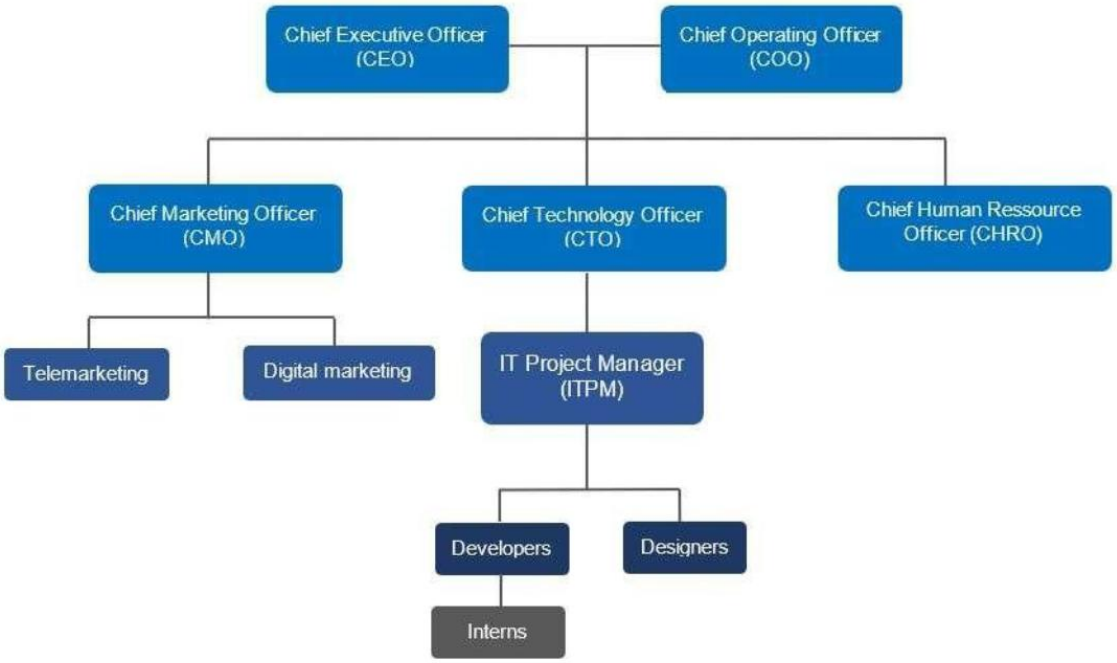



Figure 3 : Organigramme de l'UN-IT

# Chapitre 3 : Description du projet

Ce chapitre décrit le projet Mysa. Il formule d'abord la problématique de la sécurité des maisons intelligentes, puis précise l'objectif visé et les besoins des utilisateurs. Il détaille ensuite les moyens nécessaires à la réalisation, les résultats attendus et le chronogramme de travail.

## 3.1. Formulation

La multiplication des objets connectés au sein des foyers élargit considérablement la surface d'attaque des réseaux domestiques. Caméras, serrures, capteurs et assistants vocaux communiquent en permanence, souvent avec des mécanismes d'authentification faibles, des firmwares rarement mis à jour et une supervision humaine quasi inexistante. Les solutions de sécurité actuellement disponibles pour ce segment reposent en grande majorité sur une logique par signatures : elles comparent le trafic observé à une base de motifs d'attaques déjà répertoriées. Cette approche est par construction incapable de détecter une attaque inédite, une dérive progressive de comportement, ou un usage détourné d'un appareil légitime.

Ce constat conduit à formuler le problème central de ce projet : comment détecter, au sein d'un réseau domestique hétérogène, des comportements anormaux d'appareils connectés sans dépendre d'une connaissance préalable des attaques, tout en restant exploitable par un utilisateur non spécialiste de la cybersécurité ?

Le projet Mysa répond à cette question en proposant une architecture de détection comportementale : chaque appareil connecté se voit attribuer un profil d'activité normal, construit par observation continue du trafic réseau, et toute déviation significative par rapport à ce profil déclenche une alerte. Cette formulation déplace la question de « quelles attaques connaît-on ? » vers « qu'est-ce qui est normal pour cet appareil ? », ce qui permet en principe de couvrir des menaces non répertoriées.

## 3.2. Objectif et besoins de l'utilisateur

L'objectif général du projet est de concevoir, développer et valider Mysa : une architecture autonome de cybersécurité comportementale pour les écosystèmes de maisons intelligentes.

**Besoins utilisateurs :**

- Affichage de la liste des appareils connectés au réseau domestique, avec leur catégorie et leur état de connexion.

- Supervision en temps réel de l'état de chaque appareil (actif, inactif, en alerte).
- Détection des anomalies comportementales par rapport à la baseline établie pour chaque appareil.
- Calcul et affichage d'un score de risque par appareil, actualisé en continu.
- Génération d'alertes exploitables lors d'un écart comportemental significatif.
- Historique consultable des événements et des alertes survenues sur le réseau.
- Journalisation des scénarios d'attaque déclenchés lors des campagnes de validation.

### 3.3. Moyens nécessaires à la réalisation du projet (Humain, Matériel, Logiciel)

#### 3.3.1. Moyens humains :

Le projet est mené par une étudiante en Master 2 Intelligence Artificielle, parcours Objets Connectés et Cybersécurité, encadrée par un encadreur pédagogique de l'ENI pour le suivi méthodologique et par un encadreur professionnel de UN-IT pour l'accompagnement technique.

#### 3.3.2. Moyens matériels :

La réalisation de Mysa repose sur un environnement de développement pour le moteur de détection comportementale, l'API et le dashboard de supervision, ainsi que sur des jeux de données publics pour entraîner les modèles de référence. Un outil de gestion de versions assure la traçabilité du code.

#### 3.3.3. Moyens logiciels :

Un ordinateur hôte suffit au développement et à l'exécution de Mysa. Pour la démonstration lors de la soutenance, un prototype de maison intelligente (deux cartes ESP32 équipées de capteurs, un routeur MikroTik) et une plateforme d'attaque simulée permettent de montrer Mysa en conditions proches du réel.

### 3.4. Résultats attendus

Au terme du projet, les résultats suivants sont attendus :

- Un prototype de maison intelligente opérationnel, combinant appareils physiques et simulés, générant un trafic réseau représentatif.

– Un moteur Mysa capable d'établir une baseline comportementale stable pour chaque appareil du prototype.
– Un dashboard de supervision fonctionnelle, restituant en temps réel l'état et le niveau de risque des appareils.
– Un simulateur d'attaque automatisé produisant des scénarios reproductibles et journalisés.
– Un jeu de résultats quantitatifs (taux de détection, taux de faux positifs, délai de détection) démontrant l'apport de l'approche comportementale par rapport à une approche par signatures.

Ces résultats constituent la base empirique du mémoire : ils permettent de discuter, avec des données à l'appui, de la pertinence et des limites de l'approche comportementale appliquée à la sécurité des maisons intelligentes.

### 3.5. Chronogramme de travail

Le projet est planifié sur une durée de six mois, structurée en huit phases.

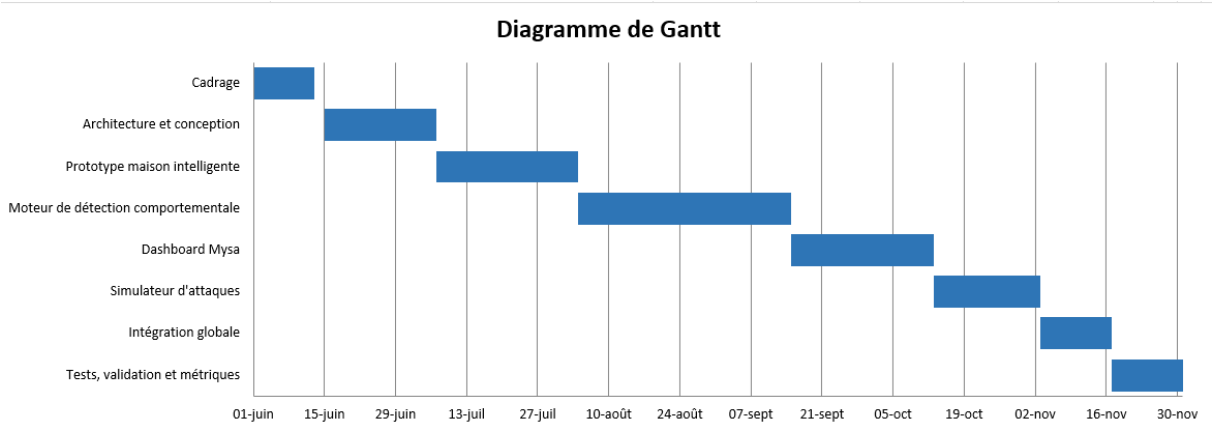



Figure 4 : Chronogramme de travail

# PARTIE II : ANALYSE ET CONCEPTION

Cette deuxième partie établit les fondements théoriques et techniques de la solution. Elle analyse l'existant pour en dégager les limites, puis propose et retient une solution. Elle présente ensuite le modèle d'architecture IoT sur lequel repose Mysa. Elle justifie enfin les outils choisis ainsi que la stratégie d'amorçage à froid des modèles de référence.

# Chapitre 4 : Analyse préalable

Ce chapitre établit le diagnostic préalable à la conception de Mysa. Il analyse l'existant, c'est-à-dire un prototype de maison intelligente volontairement non sécurisé et les solutions commerciales du marché, en critique les points forts et les points faibles, puis propose deux solutions dont l'une est retenue.

## 4.1. Analyse de l'existant

L'analyse préalable vise à établir un diagnostic objectif de l'écosystème des maisons intelligentes avant de concevoir une réponse technique. En l'absence d'une infrastructure d'entreprise unique à auditer, cette analyse porte sur l'écosystème type d'un foyer connecté : ses appareils, ses protocoles, ses pratiques de sécurité et les risques qui en découlent. Elle suit une démarche en sept étapes, inspirée des méthodologies d'audit de sécurité et adaptée au contexte d'un réseau domestique et au périmètre du prototype construit dans le cadre de ce projet.

### 4.1.1. Collecte des données existantes

Cette première étape combine deux sources d'information. D'une part, l'inventaire du prototype construit pour ce projet : un nœud « sécurité périphérique » (ESP32 n°1, capteur PIR HC-SR501, détecteur d'ouverture à aimant, buzzer) et un nœud « confort et accès » (ESP32 n°2, capteur DHT22, servomoteur SG90, module relais, lecteur RFID RC522), reliés par Wi-Fi à un broker MQTT. D'autre part, l'examen de solutions commerciales déjà présentes sur le marché de la sécurité domestique, Firewalla [15], Bitdefender BOX [16] et Fingbox [17], à partir de leur documentation technique et de tests publiés, afin de situer l'approche de Mysa par rapport à l'existant plutôt que de la concevoir dans l'abstrait.

### 4.1.2. Analyse des technologies et processus

Du côté du prototype, cette étape examine la chaîne Wi-Fi / MQTT retenue (détaillée en 5.3) : absence par défaut de chiffrement TLS sur le broker Mosquitto en configuration de base, absence d'authentification par appareil tant qu'elle n'est pas explicitement configurée, absence de protection du firmware ESP32 tant qu'elle n'est pas explicitement activée. Du côté des solutions commerciales, l'examen montre des logiques différentes mais toutes réactives : Firewalla et Bitdefender BOX s'appuient sur un filtrage par règles et des scans de vulnérabilités périodiques, de l'ordre de trois jours pour Bitdefender BOX, tandis que Fingbox se limite à la découverte d'appareils et au blocage, sans inspection du contenu des paquets. Aucune des trois ne construit de profil comportemental continu par appareil : c'est précisément l'écart que Mysa cherche à combler.

### 4.1.3. Recueil des risques et vulnérabilités

Un simple inventaire de risques ne permet pas de prioriser les actions correctives. L'évaluation suit la logique habituelle de l'analyse de risque : une menace exploite une vulnérabilité pour produire un risque, dont la criticité résulte de la combinaison de sa probabilité d'occurrence et de son impact potentiel, selon une grille à trois niveaux inspirés des méthodologies usuelles (EBIOS RM, ISO/IEC 27005 [2]).

Tableau 6 : Grille de criticité (impact en lignes, probabilité en colonnes)

| **Impact \ Probabilité** | **Faible** | **Moyenne** | **Élevée** |
|---|---|---|---|
| Faible | Faible | Faible | Moyen |
| Moyen | Faible | Moyen | Élevé |
| Élevé | Moyen | Élevé | Critique |

Vulnérabilités identifiées sur le prototype non sécurisé :

Tableau 7 : Vulnérabilités identifiées

| **Réf.** | **Vulnérabilité** | **Composant concerné** |
|---|---|---|
| V-01 | Absence de chiffrement TLS sur les communications MQTT | Broker MQTT |
| V-02 | Identifiants par défaut non modifiés sur le broker | Broker MQTT |
| V-03 | Firmware ESP32 non signé, reprogrammable sans vérification | ESP32 (nœuds) |
| V-04 | Absence de segmentation réseau par défaut | Routeur MikroTik (RouterOS) |
| V-05 | Ports de débogage UART exposés physiquement | ESP32 (nœuds) |
| V-06 | Accès physique non contrôlé au routeur | Routeur MikroTik (RouterOS) |

Une vulnérabilité ne devient un risque que si une menace est en mesure de l'exploiter. Le tableau 8 associe chaque menace à la ou aux vulnérabilités qu'elle exploite, et évalue le risque qui en résulte :

Tableau 8 : Evaluation des risques

| Réf. | Menace | Vulnérabilité exploitée | Probabilité | Impact | Criticité |
|---|---|---|---|---|---|
| R-01 | Attaquant présent sur le réseau Wi-Fi domestique interceptant le trafic | V-01 | Élevée | Élevé | Critique |
| R-02 | Attaquant ayant deviné ou trouvé les identifiants par défaut se connecte au broker | V-02 | Élevée | Élevé | Critique |
| R-03 | Attaquant disposant d'un accès temporaire reprogramme un nœud ESP32 | V-03, V-05 | Moyenne | Moyen | Moyen |
| R-04 | Un appareil compromis pivote librement vers le reste du réseau domestique | V-04 | Moyenne | Moyen | Moyen |
| R-05 | Intrus ayant un accès physique au domicile manipule directement le routeur | V-06 | Faible | Élevé | Moyen |

Deux risques ressortent en criticité critique (R-01, R-02), et tous les deux exploitent une vulnérabilité du même composant : le broker MQTT, faute de chiffrement et d'identifiants propres. Ce constat oriente directement la priorisation retenue en 4.3 et se retrouve dans la cartographie par composant.

#### 4.1.4. Cartographie de l'écosystème

Le système existant analysé dans ce chapitre est le prototype de maison intelligente tel qu'il est déployé au départ du projet : des appareils connectés opérationnels, échangeant leur télémétrie, mais sans aucune couche de supervision ni de détection de sécurité. C'est cette configuration volontairement non sécurisée qui sert de point de départ à l'analyse ; la solution destinée à y remédier, Mysa, n'est introduite qu'à partir de la section 4.3.

Dans cette configuration, les appareils connectés (les deux nœuds ESP32 et les appareils simulés) publient leur télémétrie sur un broker MQTT local, accessible depuis l'ensemble du réseau domestique via la passerelle. Cette dernière relie le réseau domestique à Internet, sans segmentation particulière entre les appareils IoT et le reste du réseau. Aucun de ces composants n'est supervisé : une intrusion sur l'un d'eux pourrait se propager sans être détectée. Chaque composant présente un niveau de criticité différent selon ce qu'il expose en cas de compromission :

Tableau 9 : Cartographie des composants et criticité

| **Composant** | **Rôle** | **Exposition** | **Criticité** |
|---|---|---|---|
| Appareils IoT (ESP32, simulés) | Capteurs / actionneurs, génèrent la télémétrie | Réseau local | Moyenne |
| Broker MQTT (Mosquitto) | Bus de messages central entre tous les appareils | Réseau local | Critique |
| Passerelle / routeur MikroTik (RouterOS) | Relie le réseau domestique à Internet, aucune segmentation activée | Frontière réseau local / Internet | Élevée |
| Internet | Vecteur d'exposition externe vers le réseau domestique | Externe | Élevée |

Cette lecture par composant converge avec l'évaluation de risques de 4.1.3 : le broker MQTT, identifié comme critique ici comme dans l'analyse de risques, concentre à lui seul deux des risques les plus élevés du projet. Aucun de ces composants ne bénéficiant d'une supervision de sécurité, cette cartographie constitue le socle sur lequel répond directement la proposition de solutions (4.3).

### 4.1.5. Sessions de feedback

Des échanges ont été menés avec l'encadreur professionnel du stage ainsi qu'avec un cercle de proches, afin de confronter l'analyse technique à des perspectives extérieures plutôt que de la mener en vase clos. Ces échanges ont porté sur deux aspects distincts. D'une part, ils ont confirmé la pertinence du volet « maison intelligente » du projet dans le contexte malgache : la demande pour ce type d'équipement y est réelle et encore peu couverte par des solutions adaptées au contexte local. D'autre part, la dimension sécurité du projet ne provient pas de ces échanges mais d'un constat personnel antérieur : la sécurité des maisons intelligentes demeure

insuffisamment traitée à l'échelle mondiale, bien au-delà du seul contexte malgache. C'est ce constat qui a orienté le projet vers Mysa plutôt que vers un simple prototype domotique dépourvu de volet cybersécurité.

#### 4.1.6. Rapport d'analyse et recommandations

La mise en commun des constats fait apparaître un écart net entre les trois solutions commerciales examinées et l'approche recherchée dans ce projet : Firewalla et Bitdefender BOX raisonnent par règles et scans périodiques, Fingbox se limite à la présence des appareils, et aucune des trois ne modélise en continu le comportement normal de chaque appareil. Les recommandations qui en découlent — construire une baseline comportementale par appareil, détecter les écarts sans dépendre d'un cloud tiers, rester lisible pour un utilisateur non expert — structurent directement la critique de l'existant (4.2) et la proposition de solutions (4.3).

#### 4.1.7. Mise à jour continue

Le paysage des menaces IoT évolue rapidement : nouveaux types d'appareils, nouveaux protocoles, nouvelles techniques d'attaque. L'analyse présentée ici n'est donc pas figée ; elle est destinée à être réexaminée à mesure que de nouveaux appareils sont intégrés au prototype ou que de nouveaux scénarios d'attaque sont envisagés pour le simulateur. Cette logique fait écho au principe même du moteur Mysa, dont la baseline comportementale est réévaluée en continu plutôt que figée une fois pour toutes (voir 6.2).

### 4.2. Critique de l'existant (points forts et points faibles)

La critique porte sur deux objets : les solutions commerciales examinées en 4.1.1 et le prototype de départ, volontairement non sécurisé (4.1.4).

Le tableau 10 en synthétise les points forts et les points faibles.

Tableau 10 : Points forts et points faibles de l'existant

| **Élément analysé** | **Points forts** | **Points faibles** |
|---|---|---|
| Firewalla [15] | Solution clé en main, filtrage par règles, utilisable par un non-spécialiste | Raisonnement par règles : aucun profil de comportement continu par appareil |
| Bitdefender BOX [16] | Scans de vulnérabilités intégrés à une offre grand public | Scans périodiques, de l'ordre de trois jours : fenêtre |

| | | |
|---|---|---|
| | | d'exposition longue ; aucun profil comportemental |
| Fingbox [17] | Découverte des appareils et blocage, mise en œuvre simple | Pas d'inspection du contenu des paquets ; aucune modélisation du comportement |
| Prototype de départ (4.1.4) | Chaîne légère Wi-Fi / MQTT adaptée aux ESP32 ; base de comparaison pour mesurer l'apport de chaque mesure | Aucun chiffrement ni identifiants propres, aucune segmentation, aucune supervision (R-01 et R-02 critiques) |

Les mécanismes par signatures et par règles, communs à ces offres, détectent des menaces connues mais ne couvrent pas, par construction, les comportements inédits. Aucune de ces solutions ne comble l'écart relevé en 4.1.6, qui consiste à modéliser en continu le comportement normal de chaque appareil. Quant au prototype de départ, il concentre ses risques critiques sur le broker MQTT (4.1.3). Deux besoins en découlent : durcir les composants (chiffrement, authentification, segmentation) et superviser le comportement des appareils. La proposition de solutions (4.3) répond à ces deux besoins.

## 4.3. Proposition de solutions

Deux approches ont été envisagées pour répondre à la problématique formulée en 3.1. Toutes deux s'appuient sur un même socle de durcissement préventif, issu de l'évaluation des risques (4.1.3) : chiffrement TLS, comptes individuels et listes de contrôle d'accès sur le broker (V-01, V-02), segmentation en VLAN (V-04). Elles diffèrent par le mécanisme de détection.

**Solution 1 : détection par signatures (système de détection d'intrusion classique)**

Cette approche repose sur un système de détection d'intrusion s'appuyant sur une base de règles et de signatures d'attaques connues, du type de ceux qui analysent le trafic réseau à la recherche de motifs répertoriés.

- Points forts : solution mature et largement documentée, faible taux de fausses alertes sur les attaques déjà répertoriées, mise en œuvre rapide à l'aide d'outils existants.

- Points faibles : incapacité à détecter des attaques inconnues, maintenance continue de la base de signatures, absence d'adaptation au comportement propre de chaque appareil ; une signature décrit un trafic ou un protocole, et ne permet pas d'exprimer qu'une valeur publiée par un compte légitime est aberrante pour cet appareil.

**Solution 2 : détection comportementale par apprentissage de baseline (approche retenue)**

Cette approche consiste à construire, pour chaque appareil connecté, un profil d'activité normal à partir de sa télémétrie, puis à signaler tout écart significatif par rapport à ce profil.

- Points forts : capacité à détecter des comportements inédits sans connaissance préalable de la menace, adaptation individuelle à chaque catégorie d'appareil, cohérence avec l'hétérogénéité d'un parc d'objets connectés domestiques, fonctionnement local.
- Points faibles : nécessité d'une phase d'apprentissage avant que la détection ne soit pleinement opérationnelle, risque de fausses alertes durant cette phase initiale, complexité de mise en œuvre supérieure à celle d'une solution par signatures.

Le tableau 11 compare les deux solutions selon les critères déterminants pour un foyer.

Tableau 11 : Comparaison des deux solutions

| **Critère** | **Solution 1 : signatures** | **Solution 2 : comportementale** |
|---|---|---|
| Menaces inconnues | Non détectées par construction | Détectées si elles modifient le comportement observé |
| Compte légitime détourné | Non exprimable par une signature | Détecté comme écart par rapport à la baseline |
| Adaptation à chaque appareil | Règles génériques | Profil propre à chaque appareil |
| Phase d'apprentissage | Aucune | Nécessaire ; atténuée par l'amorçage à froid (6.2) |
| Maintenance | Mise à jour continue des signatures | Ré-entraînement du modèle local |
| Complexité de mise en œuvre | Faible (outils existants) | Plus élevée (modèles, données de référence) |

La solution 2 a été retenue. Dans un foyer, la menace principale visée par ce projet n'est pas un trafic reconnaissable mais un compte légitime détourné ou un nœud compromis publiant des valeurs aberrantes, situations qu'une signature ne sait pas décrire. L'hétérogénéité des objets connectés rend en outre difficile le maintien d'une base de signatures exhaustive, alors qu'une approche comportementale s'adapte au profil de chaque appareil et fonctionne localement, comme le recommande 4.1.6. Sa principale faiblesse, la fenêtre d'exposition initiale, est traitée par la stratégie d'amorçage à froid présentée en 6.2.

La solution retenue se compose de trois éléments introduits en 3.1 : un prototype de maison intelligente, l'application Mysa (moteur de détection et dashboard) et un simulateur d'attaque. Le durcissement préventif traite les risques critiques R-01 et R-02 ainsi que R-04, tandis que la détection comportementale couvre le risque résiduel de compromission d'un nœud (R-03) ; R-05, lié à l'accès physique au routeur, reste hors du périmètre d'automatisation.

# Chapitre 5 : Modèle et architecture de l'IoT

Ce chapitre présente le modèle d'architecture IoT sur lequel repose Mysa. Il rappelle le cadre conceptuel en couches, décrit la couche dispositifs et les technologies de la couche réseau, représente l'architecture appliquée au prototype, la situe parmi les modèles de référence normalisés et en expose les limites.

## 5.1. Cadre conceptuel et fondements du modèle IoT

Mysa s'organise en quatre couches, inspirées de la recommandation ITU-T Y.2060 [3] : dispositifs, réseau, support aux services et aux applications, application, la sécurité étant traitée comme une capacité transversale.

## 5.2. Conception et rôle de la couche perception

La couche de perception du prototype regroupe l'ensemble des appareils physiques et virtuels produisant de la télémétrie. Deux nœuds ESP32 physiques assurent la collecte de données réelles :

- Le premier nœud, dédié à la sécurité périmétrique, regroupe un capteur de mouvement PIR HC-SR501, un buzzer et une LED de signalisation.
- Le second nœud, dédié au contrôle d'accès et au confort, regroupe un lecteur RFID, un servomoteur simulant une serrure motorisée, un module relais et un capteur DHT22 de température et d'humidité.

Ces deux nœuds sont complétés par des appareils simulés (caméra, ampoule, prise connectée), générés par script et rattachés à un segment réseau distinct. Ils élargissent la diversité du parc supervisé sans matériel supplémentaire. Chaque appareil est identifié par un device_id unique, qui sert à la fois de nom de compte sur le broker et de composant du topic de publication (5.3).

## 5.3. Technologies de connectivité et protocoles de transmission dans la couche réseau

Au sein de la couche réseau, les nœuds ESP32 se connectent en Wi-Fi au routeur, puis publient leur télémétrie vers un broker MQTT [7] chiffré par TLS sur le port 8883. Le modèle de publication/abonnement découple les appareils du moteur de détection : celui-ci s'abonne à l'ensemble des topics sans que les appareils aient connaissance de son existence. La comparaison avec CoAP et HTTP, qui justifie le choix de MQTT, est présentée en 6.1.2.

Les appareils publient selon la convention home/<device_id>/<sensor>, avec une charge utile au format JSON (device_id, sensor, value, unit, ts) ; la convention complète figure en 7.1. La

confidentialité et l'authentification reposent sur TLS et sur un compte par appareil, l'isolation entre segments sur les VLANs (5.4).

Entre le moteur et le dashboard, la communication s'appuie sur une API REST (HTTP), complétée à terme par un flux WebSocket pour les alertes en temps réel (7.3).

## 5.4. Modélisation schématique d'une architecture IoT appliquée

L'architecture appliquée du prototype est représentée par la figure 5. Elle superpose les quatre couches du modèle retenu et la sécurité transversale.

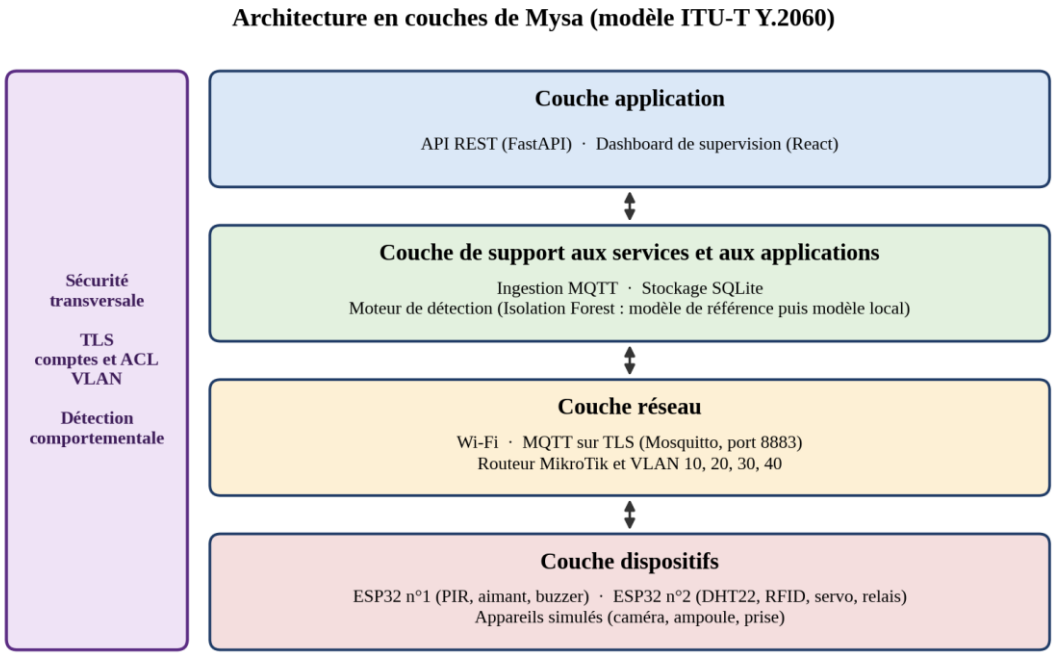



Figure 5 : Architecture en couches de Mysa

La segmentation réseau (figure 5.2) repose sur quatre VLAN, mis en œuvre à l'aide d'un routeur MikroTik, simulé par RouterOS CHR sous GNS3 en attendant le routeur physique : le VLAN 10 regroupe les nœuds physiques, le VLAN 20 les appareils simulés, le VLAN 30 le hub qui héberge le broker, le moteur, l'API et la base de données, et le VLAN 40 la plateforme d'attaque. Seuls les flux MQTT chiffrés des VLAN 10 et 20 vers le VLAN 30 sont autorisés ; tout autre flux inter-VLAN est refusé, et l'accès du VLAN 40 aux cibles n'est ouvert que pendant un scénario d'attaque. Le moteur étant lui-même un client du broker, aucune capture du trafic réseau n'est nécessaire à la détection : la segmentation sert à l'isolation, non à l'observation.

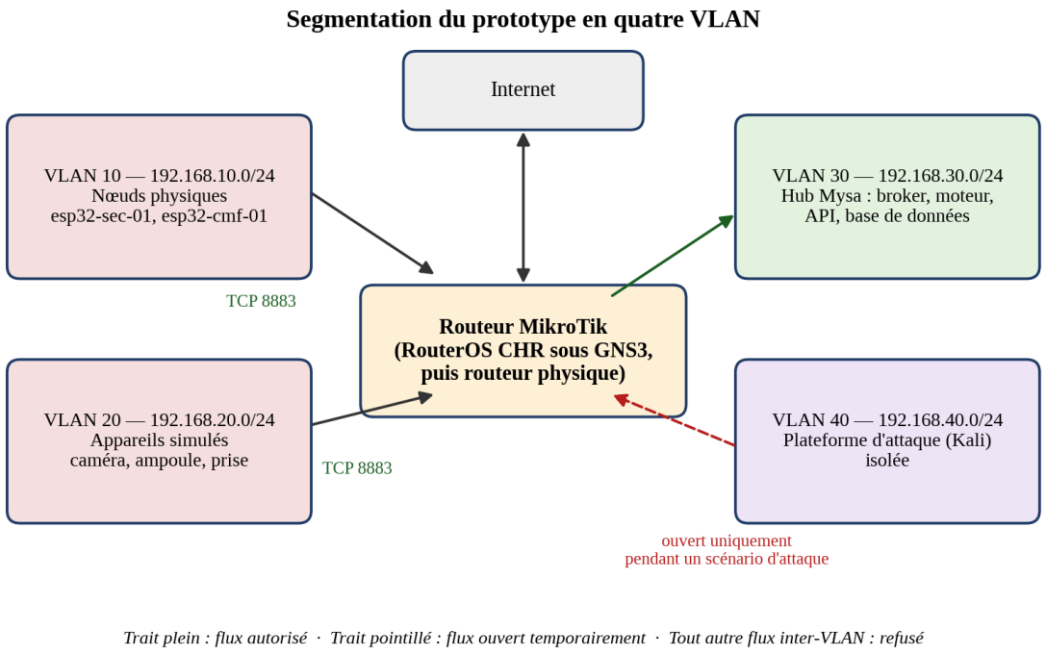



Figure 6 : Segmentation du prototype en quatre VLAN

### 5.5. Analyse comparative des modèles de référence normalisés

Le choix du modèle de référence a une conséquence pratique : il détermine où se place le moteur de détection dans l'architecture.

Le tableau 12 compare les modèles examinés sous cet angle.

Tableau 12 : Positionnement de Mysa par rapport aux modèles de référence

| **Modèle** | **Ce qu'il apporte** | **Conséquence pour Mysa** |
|---|---|---|
| Trois couches : perception, réseau, application [4] | Découpage minimal, très répandu | Ingestion, stockage et détection se retrouvent mêlés à l'interface : le moteur, cœur du projet, n'a pas de place identifiée |
| ITU-T Y.2060 [3] (retenu) | Quatre couches et capacités de sécurité transversales | Le moteur occupe la couche de support aux services ; la sécurité (TLS, ACL, VLAN, détection) est transversale |

| | | |
|---|---|---|
| oneM2M [5] et ETSI M2M [6] | Plateformes de services communs entre fabricants | Utiles à grande échelle ; hors périmètre d'un prototype à un seul hub |

Mysa retient donc la structure en quatre couches de la recommandation Y.2060 : elle donne au moteur de détection une place explicite, et fait de la sécurité comportementale une capacité transversale effectivement mise en œuvre plutôt qu'une couche ajoutée après coup.

### 5.6. Limites techniques et défis d'ingénierie de l'architecture IoT

Six limites techniques ont été identifiées au cours de la conception de l'architecture.

- **Fenêtre d'exposition.** Dans sa version initiale, le moteur n'évaluait un flux qu'après les 24 premiers messages et construisait sa baseline sur ces seuls premiers instants, sans garantie de représentativité. L'amorçage à froid (6.2) atténue cette limite sans la supprimer.
- **Alertes en grappes.** Le moteur analyse des fenêtres glissantes : une même déviation produit plusieurs alertes consécutives, ce qui impose de les regrouper en épisodes pour les mesures (9.1).
- **Appareil silencieux.** L'arrêt d'un appareil n'est pas détecté en l'état, le moteur n'évaluant que les messages reçus (scénario SC-05).
- **Diversité limitée du parc.** Deux nœuds physiques seulement produisent de la télémétrie réelle ; les appareils simulés et les données publiques compensent partiellement cette limite (6.2).
- **Catégories sans référence.** Le lecteur RFID, le servomoteur et le relais n'ont pas de modèle de référence public et apprennent depuis zéro (6.2.2).

# Chapitre 6 : Études et choix des outils

Ce chapitre expose la méthodologie de conception de Mysa et les outils retenus. Il justifie d'abord le choix de chaque technologie, puis la modélisation du moteur de détection et sa stratégie d'amorçage à froid à partir de données publiques. Il précise ensuite l'intégration des couches, le suivi des performances, la sécurité et la conformité, avant de synthétiser l'ensemble des choix.

## 6.1. Outils utilisés

Le choix de chaque outil résulte d'une mise en balance entre plusieurs alternatives matures, évaluées selon des critères constants : maturité de l'écosystème, courbe d'apprentissage, performance et adéquation avec les contraintes du projet. Cette section détaille cette étude pour chaque brique technologique du projet.

### 6.1.1. Outils de développement firmware

Tableau 13 : Alternatives pour le firmware ESP32

| **Alternative** | **Avantages** | **Inconvénients** |
|---|---|---|
| Framework Arduino (retenu) | Simplicité, large bibliothèque de pilotes de capteurs, communauté importante | Moins de contrôle bas niveau |
| ESP-IDF (natif Espressif) | Contrôle fin du matériel, performance optimale | Complexité et courbe d'apprentissage élevées |
| MicroPython | Prototypage rapide en Python | Moins adapté aux contraintes temps réel des capteurs utilisés |

Sources : documentation de PlatformIO [18], d'ESP-IDF [19] et de MicroPython [20].

Le framework Arduino, utilisé via PlatformIO, est retenu : sa simplicité et sa bibliothèque de pilotes couvrent largement les besoins du prototype, sans justifier la complexité additionnelle d'ESP-IDF.

### 6.1.2. Protocole et broker de communication IoT

Le tableau 14 compare les trois protocoles envisagés pour la communication entre les appareils et le moteur Mysa.

Tableau 14 : Comparaison de MQTT, CoAP et HTTP/REST

| **Critère** | **MQTT** | **CoAP** | **HTTP/REST** |
|---|---|---|---|
| Modèle de communication | Publication/abonnement via un broker | Requête/réponse (REST) | Requête/réponse (REST) |
| Transport | TCP | UDP | TCP |
| Empreinte protocolaire | Faible (en-tête minimal) | Très faible | Plus élevée (en-têtes textuels) |
| Fiabilité | Trois niveaux de qualité de service (0, 1, 2) | Messages confirmables ou non | Assurée par TCP, sans qualité de service applicative |
| Sécurité | TLS | DTLS | TLS (HTTPS) |
| Découplage appareils / moteur | Fort : le broker s'interpose | Faible : échange direct | Faible : échange direct |
| Décision pour le projet | Retenu | Écarté : modèle requête/réponse, couplage direct | Écarté : empreinte plus élevée, pas de publication native |

Sources : [4], [7], [8], [9].

MQTT [7] (broker Mosquitto [21]) est retenu face à CoAP [8] et HTTP/REST [9] : son modèle publication/abonnement limite le couplage entre les appareils et le moteur Mysa, son empreinte protocolaire est faible et compatible avec les contraintes des ESP32, et son adoption massive dans l'IoT domestique garantit des bibliothèques matures et bien documentées, tant côté firmware que côté serveur Python. Mosquitto offre en natif l'authentification par compte, le chiffrement TLS et le contrôle d'accès par liste (ACL), trois mécanismes directement mobilisés pour traiter les vulnérabilités V-01 et V-02.

### 6.1.3. Outils d'apprentissage automatique pour la détection d'anomalies

scikit-learn[11] est retenu pour le moteur comportemental, avec l'algorithme Isolation Forest[10]. Ce choix répond à trois contraintes :

- La détection doit être non supervisée, aucune attaque étiquetée n'étant disponible pour un appareil donné au moment de son installation ;
- Les données sont tabulaires et de faible dimension ;
- Le modèle doit être entraînable sur un nombre réduit d'échantillons et s'exécuter localement sur une machine modeste. Isolation Forest isole les observations atypiques par partitionnements aléatoires successifs : plus un point est isolé rapidement, plus il est jugé anormal.

Isolation Forest ne se met pas à jour de façon incrémentale : l'adaptation à un appareil passe donc par un ré-entraînement périodique sur une fenêtre glissante d'échantillons récents. TensorFlow et PyTorch ont été jugés disproportionnés pour ces données tabulaires ; River [22], qui propose des détecteurs incrémentaux, reste une piste pour des travaux futurs.

### 6.1.4. Framework backend et API

FastAPI est retenu face à Flask, Django et Node/Express : son typage natif réduit les erreurs d'intégration avec le moteur de détection, ses performances asynchrones conviennent à un flux de télémétrie continu, sa documentation interactive générée automatiquement (/docs) facilite les tests, et son intégration avec l'écosystème Python scientifique utilisé pour l'analyse comportementale est directe.

### 6.1.5. Stockage de la télémétrie

Tableau 15 : Alternatives pour le stockage

| **Alternative** | **Avantages** | **Inconvénients** |
|---|---|---|
| SQLite (retenu) | Aucun service à installer ni sécuriser, fichier unique, suffisant pour un prototype sur une seule machine | Un seul écrivain à la fois ; ne passe pas à l'échelle d'un déploiement multi-foyers |
| InfluxDB | Conçu pour les séries temporelles, requêtes temporelles natives | Service supplémentaire à installer, sécuriser et maintenir |
| PostgreSQL | Robuste, concurrent, extensible (TimescaleDB) | Service lourd pour un prototype à une machine |

SQLite [24] est retenu : le prototype tourne sur une seule machine virtuelle, et ajouter un service de base de données élargirait inutilement la surface d'attaque que le projet cherche à réduire. InfluxDB constitue la piste naturelle si le volume de télémétrie ou le nombre de foyers devait croître.

#### 6.1.6. Framework frontend et visualisation

React [25], associé à la bibliothèque Recharts [26] et à une connexion WebSocket pour les mises à jour en temps réel, est retenu face à Vue et Angular pour sa large communauté, la disponibilité de composants de visualisation éprouvés et la réactivité nécessaire à un dashboard de supervision en direct. Grafana, qui permettrait d'obtenir rapidement des tableaux de bord, a été écarté : le dashboard vise deux profils d'utilisateurs (3.2), dont un non spécialiste, ce qui suppose une interface sur mesure (état par appareil, alertes regroupées par épisode, vocabulaire sans jargon) plutôt qu'un outil générique de visualisation de séries temporelles. Le développement du dashboard est planifié après la stabilisation du moteur (voir 8.8) ; en attendant, l'API documentée par FastAPI permet la consultation des appareils et des alertes.

#### 6.1.7. Environnement de virtualisation et de simulation réseau

VMware Workstation [27] est retenu comme hub logiciel du prototype : gratuit, multiplateforme et suffisant pour héberger le broker MQTT, les appareils simulés, le backend de Mysa et la machine Kali. La segmentation en VLAN est simulée avec GNS3 [28] et un routeur virtuel MikroTik RouterOS CHR [29], en attendant le routeur MikroTik physique. Docker constitue une alternative plus légère, envisageable pour une phase ultérieure de conteneurisation.

#### 6.1.8. Outils de test d'intrusion

Kali Linux [30] est retenu face à des distributions comparables comme Parrot OS : il s'agit de la distribution de référence en test d'intrusion, avec une documentation abondante et un ensemble d'outils préinstallés (nmap, hydra, Wireshark, clients MQTT) couvrant l'ensemble des scénarios d'attaque prévus pour éprouver Mysa.

#### 6.1.9. Outils de gestion de projet et de version

Git, avec un dépôt hébergé sur GitHub[31], assure la traçabilité des évolutions du code sur l'ensemble des trois composants du projet, condition nécessaire pour documenter précisément, dans le mémoire, l'historique des choix techniques et des itérations successives.

## 6.2. Données et stratégie d'amorçage à froid

La conception de la solution comporte deux volets. Le volet matériel et logiciel d'ensemble (prototype, blocs de Mysa) est décrit au chapitre 7 et mis en œuvre au chapitre 8. Le volet de modélisation, central pour une approche comportementale, porte sur la manière dont le moteur obtient, pour chaque appareil, une référence de comportement normal ; il fait l'objet de la présente section.

### 6.2.1. Problème : le démarrage à froid

Au branchement d'un appareil, Mysa n'a aucune observation de lui. Dans la version initiale, le moteur entraînait un modèle vierge sur les premiers vecteurs de caractéristiques : la baseline n'était disponible qu'après 24 messages (5.6) et reposait sur les tout premiers instants de l'appareil, sans garantie qu'ils soient représentatifs ni sains. Cette période est la fenêtre d'exposition.

Pour la réduire, Mysa démarre chaque flux avec un modèle de référence de sa catégorie, entraîné sur des données publiques, avant de basculer vers un modèle appris sur la télémétrie réelle de l'appareil. Cette démarche s'apparente au transfert de connaissances appliqué au démarrage à froid [12].

Exemple : le flux home/esp32-sec-01/pir est rattaché à la catégorie « mouvement ». Ses premières fenêtres sont évaluées par le modèle entraîné sur IoT_Motion_Light ; après vingt échantillons normaux, un modèle propre au capteur prend le relais.

### 6.2.2. Datasets publics retenus

**TON_IoT (télémétrie IoT).** Produit par l'UNSW Canberra, TON_IoT regroupe des données de télémétrie de capteurs IoT et IIoT, des journaux de systèmes d'exploitation et du trafic réseau, collectés sur un banc d'essai mêlant événements normaux et attaques [13][32]. Son usage est libre à des fins de recherche académique, sous réserve de citer les publications des auteurs. Les jeux de télémétrie sont fournis par type d'appareil, avec un horodatage, la ou les valeurs mesurées, une étiquette binaire (normal / attaque) et un type d'attaque. Cette organisation par appareil correspond exactement au besoin : un dataset, une catégorie.

Tableau 16 : Jeux de télémétrie TON_IoT et catégories Mysa associées

| **Dataset TON_IoT** | **Grandeurs mesurées** | **Instances*** | **Catégorie Mysa** | **Capteur du prototype** |
|---|---|---|---|---|

| | | | | |
|---|---|---|---|---|
| IoT_Motion_Light | motion_status, light_status | 452 263 | mouvement | PIR HC-SR501 |
| IoT_Garage_Door | door_state, sphone_signal | 591 447 | ouverture | Détecteur à aimant |
| IoT_Weather | temperature, pressure, humidity | 650 243 | environnemental | DHT22 |
| IoT_Thermostat | current_temperature, thermostat_status | 442 229 | environnemental (complément possible) | DHT22 |
| IoT_GPS_Tracker | latitude, longitude | 595 687 | géolocalisation | Aucun (extension) |
| IoT_Fridge | fridge_temperature, temp_condition | 587 077 | non retenu | Aucun |

Effectifs repris de la description publiée du jeu de données [13]. Aucun jeu ne correspond au lecteur RFID, au servomoteur ni au relais : ces flux n'ont pas de modèle de référence et apprennent depuis zéro.

**CICIoT2023.** Ce dataset du Canadian Institute for Cybersecurity décrit du trafic réseau d'un parc de 105 appareils IoT soumis à 33 attaques regroupées en sept catégories [14][33]. Il décrit le **trafic réseau** (flux et paquets) et non la télémétrie applicative d'une catégorie de capteurs. Or, dans sa version actuelle, Mysa analyse la télémétrie MQTT. CICIoT2023 n'est donc pas utilisé pour entraîner les modèles de référence ; il est conservé comme source pour une extension future de la détection au niveau des flux réseau (voir perspectives). Ce positionnement corrige la formulation initiale du projet, qui envisageait d'utiliser les deux datasets de la même manière.

### 6.2.3. Principe : un modèle par catégorie, jamais de mélange

Le principe retenu comporte trois règles.

- **Un modèle de référence par catégorie, un dataset par modèle.** Chaque modèle de référence est un Isolation Forest entraîné séparément sur le seul dataset de sa catégorie, uniquement sur les fenêtres de télémétrie normales. Les datasets ne sont jamais fusionnés : un modèle entraîné sur l'ensemble produirait un comportement « moyen »

de l'IoT, c'est-à-dire exactement le profil unique et peu discriminant que l'approche par appareil cherche à éviter.

- **Association par le nom du capteur.** Lorsqu'un nouveau flux apparaît, Mysa lui associe la catégorie la plus proche d'après le nom de son capteur (6.2.4). Sans correspondance, le flux apprend depuis zéro.
- **Démarrage sur la référence, puis bascule vers le local et affinage.** Le flux est protégé par le modèle de référence dès sa première fenêtre complète. Dès que suffisamment d'échantillons normaux de l'appareil sont réunis, un modèle local est entraîné sur ses propres caractéristiques et remplace la référence. Ensuite, le modèle local est ré-entraîné périodiquement sur une fenêtre glissante des échantillons normaux les plus récents.

Tableau 17 : Les trois régimes de fonctionnement d'un flux

| **Régime** | **Condition** | **Modèle qui décide** | **Apprentissage** |
|---|---|---|---|
| 1. Amorçage | Pas encore de modèle local ; catégorie reconnue et référence disponible | Modèle de référence de la catégorie | Accumulation d'échantillons normaux locaux (un tous les 5 messages) |
| 1 bis. Amorçage sans référence | Catégorie inconnue *Les trois régimes de fonctionnement d'un flux* ou référence absente ou rejetée | Aucun (pas de détection) | Accumulation, comme dans la version initiale |
| 2. Bascule | 20 échantillons normaux locaux réunis | Modèle local (nouvellement entraîné) | Entraînement initial |
| 3. Affinage | Modèle local actif | Modèle local | Ré-entraînement tous les 20 nouveaux échantillons sur les 200 plus récents |

Isolation Forest n'étant pas incrémental, le transfert ne consiste pas à régler finement un modèle existant : la référence sert de détecteur pendant l'amorçage, puis le modèle local, entraîné sur

l'appareil, la remplace. L'affinage désigne le ré-entraînement périodique de ce modèle local, qui lui permet de suivre la dérive lente du comportement normal.

#### 6.2.4. Association capteur–catégorie

Tableau 18 : Association entre nom de capteur et catégorie

| **Nom de capteur publié** | **Catégorie associée** | **Dataset de référence** |
|---|---|---|
| pir (HC-SR501) | mouvement | IoT_Motion_Light |
| magnet, reed, door | ouverture | IoT_Garage_Door |
| dht22, temperature, humidity | environnemental | IoT_Weather |
| gps | géolocalisation | IoT_GPS_Tracker (aucun capteur correspondant sur le prototype) |
| rfid, servo, relay, autre | aucune | Apprentissage depuis zéro |

L'association repose sur des mots-clés présents dans le nom du capteur (correspondance exacte d'abord, puis par inclusion). C'est volontairement simple et transparent ; une association fondée sur le profil statistique du flux plutôt que sur son nom serait une amélioration possible.

#### 6.2.5. Caractéristiques portables et caractéristiques locales

Un modèle entraîné sur un dataset ne peut être appliqué à un appareil réel que si les deux sont décrits par les mêmes caractéristiques, calculées de la même façon. Mysa utilise donc une unique fonction de calcul sur fenêtres de 20 messages consécutifs, appliquée aussi bien aux données publiques qu'à la télémétrie réelle. Deux jeux de caractéristiques sont distingués :

Tableau 19 : **Caractéristiques d'une fenêtre de 20 messages**

| **Caractéristique** | **Définition Caractéristiques d'une fenêtre de 20 messages** | **Portable (référence)** | **Locale** |
|---|---|---|---|
| mean_abs_delta | Variation absolue moyenne entre valeurs consécutives | Oui | Oui |
| std_value | Écart-type des valeurs | Oui | Oui |
| unique_ratio | Proportion de valeurs distinctes | Oui | Oui |
| cv_interval | Coefficient de variation des intervalles entre messages | Non | Oui |
| mean_value | Valeur moyenne | Non | Oui |
| mean_interval_s | Intervalle moyen entre messages (s) | Non | Oui |

| | | | |
|---|---|---|---|
| std_interval_s | Écart-type des intervalles (s) | Non | Oui |

Les caractéristiques de rythme et de niveau sont exclues des modèles de référence car elles dépendent de l'appareil et non de la catégorie : une température moyenne mesurée dans un laboratoire australien n'est pas celle d'un salon malgache, et un capteur échantillonné de façon irrégulière ne se comporte pas comme un ESP32 publiant à période fixe. Un essai l'a confirmé: une référence incluant la régularité des intervalles classait comme anormal tout flux périodique. Le prix de cette portabilité est une référence plus grossière, sensible à la dynamique des valeurs (pics, valeurs figées) mais pas aux changements de rythme, que seul le modèle local détecte.

#### 6.2.6. Garde-fous et limites

- **Protection contre l'empoisonnement de la baseline.** Une fenêtre jugée anormale, par la référence comme par le modèle local, n'est jamais ajoutée à l'historique d'apprentissage. Un appareil compromis dès son installation ne voit ainsi pas son comportement anormal appris comme normal.
- **Garde de compatibilité de la référence.** Si la référence classe en anomalie plus de la moitié des dix premières fenêtres d'un flux, elle est abandonnée, un avis de sévérité faible est enregistré et le flux apprend depuis zéro. Cette garde traite le décalage entre le dataset et l'appareil, mais elle ne peut pas le distinguer d'une attaque présente dès le démarrage : sans étiquette, les deux cas sont indiscernables.
- **Nature des attaques de TON_IoT.** Les attaques du dataset ciblent la passerelle et les services (dénis de service, injections, mots de passe, etc.) ; leur effet sur les valeurs de télémétrie elles-mêmes peut être faible. Le taux de détection mesuré hors ligne sur ces datasets (9.4) ne doit donc pas être lu comme la performance de Mysa face à les scénarios d'attaque du projet (9.3).
- **Représentativité.** Les conditions de collecte (matériel, localisation, période d'échantillonnage) diffèrent de celles du prototype ; la référence ne peut qu'approcher le comportement normal d'une catégorie.
- **Historique d'apprentissage volatile.** L'historique des échantillons normaux est conservé en mémoire vive tant qu'aucun modèle local n'a été entraîné ; il est perdu en cas de redémarrage du moteur pendant cette période.

### 6.2.7. Protocole d'évaluation prévu

L'apport de l'amorçage n'est pas présumé : il fait l'objet d'une évaluation comparant deux configurations du moteur, **apprentissage depuis zéro** et **référence puis local**, sur les mêmes scénarios. Trois hypothèses sont testées :

- **H1.** Lorsqu'une attaque débute pendant la phase d'amorçage, la configuration avec référence en détecte une proportion plus élevée que la configuration depuis zéro, grâce à une baseline non empoisonnée ;
- **H2.** Après la bascule, les performances de la configuration avec référence sont au moins égales à celles de la configuration depuis zéro ;
- **H3.** La référence n'augmente pas le taux de fausses alertes en phase d'amorçage au-delà d'un seuil acceptable.

Les mesures retenues (taux de détection, taux de fausses alertes, délai de détection, nombre d'épisodes d'alerte) sont définies en 9.1. Aucun résultat n'est avancé ici : ils seront renseignés au chapitre 9 après exécution.

### 6.2.8. Synthèse du choix technologique

Tableau 20 : Synthèse des outils retenus

| **Catégorie** | **Outil retenu** |
|---|---|
| Firmware ESP32 | Arduino / PlatformIO |
| Communication IoT | MQTT (Mosquitto) sur TLS, authentification et ACL |
| Détection comportementale | Python / scikit-learn (Isolation Forest) |
| Données de référence | TON_IoT (télémétrie), un modèle par catégorie ; CICIoT2023 réservé aux perspectives |
| Backend / API | FastAPI |
| Stockage | SQLite |
| Dashboard | React + WebSocket + Recharts (à réaliser) |
| Hub logiciel | VMWare (Ubuntu Server) |
| Segmentation réseau | GNS3 + MikroTik RouterOS CHR, puis routeur physique |
| Simulateur d'attaque | Kali Linux (nmap, hydra, outils MQTT) |
| Gestion de versions | Git / GitHub |

# PARTIE III : RÉALISATION

Cette troisième partie traduit la conception en un prototype fonctionnel. Elle présente l'environnement de réalisation : le prototype de maison intelligente, la plateforme d'attaque et l'architecture de Mysa. Elle détaille ensuite l'installation et la configuration de chaque composant. Elle définit enfin le protocole de test et de validation de la détection comportementale.

# Chapitre 7 : Présentation de l'environnement

Ce chapitre présente l'environnement dans lequel Mysa est réalisé : le prototype de maison intelligente, la plateforme d'attaque et l'architecture logicielle de Mysa. Le chapitre 8 en détaille ensuite la mise en œuvre étape par étape, et le chapitre 9 la validation.

## 7.1. Prototype de maison intelligente

Le prototype combine deux nœuds physiques et des appareils simulés, reliés au réseau segmenté décrit en 5.4. Chaque nœud possède un identifiant unique, qui sert à la fois d'identité MQTT et de nom de compte sur le broker. Le tableau 21 recense les appareils du prototype.

Tableau 21 : Appareils du prototype

| Appareil | Type | Capteurs | Actionneurs | VLAN |
|---|---|---|---|---|
| esp32-sec-01 | Physique (ESP32 n°1) — sécurité périphérique | PIR HC-SR501, détecteur d'ouverture à aimant | Buzzer | 10 |
| esp32-cmf-01 | Physique (ESP32 n°2) — confort et accès | DHT22 (température, humidité), lecteur RFID RC522 | Servomoteur SG90, relais | 10 |
| Caméra, ampoule, prise connectée | Simulés (logiciel) | Métadonnées simulées | Simulés | 20 |

**Convention de topics et de messages.** Tous les appareils publient selon une convention unique, que le moteur d'ingestion exploite :

- topic de télémétrie : home/<device_id>/<sensor> (exemple : home/esp32-sec-01/pir) ;
- topic de commande : home/<device_id>/cmd/<actionneur>, publié par l'API et ignoré par le moteur d'ingestion ;
- charge utile au format JSON, avec les champs device_id, sensor, value, unit et ts. Le champ ts (horodatage ISO 8601) est facultatif : en son absence, le moteur horodate le message à sa réception.

Figure 7 : Photographie du montage des deux nœuds ESP32

Figure 8 : Capture des messages MQTT reçus par le broker pour chaque appareil

## 7.2. Plateforme d'attaque

La plateforme d'attaque est une machine virtuelle Kali Linux placée dans un VLAN dédié et isolé (VLAN 40). Elle est volontairement séparée du dashboard et du moteur Mysa : aucun code n'est partagé entre les deux, afin que le simulateur éprouve Mysa comme le ferait un attaquant extérieur, sans connaître son fonctionnement interne. Les scénarios y sont organisés dans un dépôt dédié (dossier attack-lab/), chacun relié à un risque évalué au chapitre 4 (R-01 à R-05) et à un test d'intrusion du chapitre 9 (TI-01 à TI-05). Les scénarios sont détaillés dans les tableaux 8.6 et 8.7, leur mise en œuvre en 8.9 et leurs résultats au chapitre 9.

## 7.3. Présentation de Mysa

L'application Mysa regroupe le moteur d'ingestion et de détection, le stockage de la télémétrie (SQLite), l'API de consultation (FastAPI) et, à terme, le tableau de bord de supervision (React). Le tableau de bord présente la liste des appareils connectés, leur état en temps réel, leur score de risque, ainsi que l'historique des alertes générées.

Mysa est organisé en blocs successifs, du message MQTT reçu à l'alerte affichée :

Tableau 22 : Blocs logiciels de Mysa et fichiers correspondants

| **Bloc** | **Rôle** | **Fichier(s)** |
|---|---|---|
| Ingestion | S'abonne à home/#, valide et enregistre chaque message, déclenche l'analyse | engine/ingest.py |
| Stockage | Base SQLite : tables telemetry et alerts | engine/storage.py |
| Caractéristiques | Calcule, par flux capteur, les caractéristiques d'une fenêtre de 20 messages | engine/features.py |
| Catégories | Associe un capteur à une catégorie d'appareil | engine/categories.py |
| Modèle de référence | Charge et applique le modèle de la catégorie (amorçage) | engine/reference.py |
| Modèle local | Entraîne et applique le modèle propre à un flux | engine/model.py |
| Orchestration | Choisit le régime (amorçage, bascule, affinage) et lève les alertes | engine/analyzer.py |

| | | |
|---|---|---|
| API | Expose appareils, historiques et alertes au dashboard | api/main.py, api/routes/ |
| Entraînement des références | Entraîne un modèle de référence à partir d'un CSV public | scripts/train_reference.py |
| Score de risque | Agrège les épisodes d'alerte récents en un score par appareil (8.5.5) | engine/risk.py (à réaliser) |

L'API expose ces données au dashboard ; ses points d'accès sont récapitulés dans le tableau 23.

Tableau 23 : Points d'accès de l'API

| **Méthode et chemin** | **Description** |
|---|---|
| GET / | État du service |
| GET /api/devices | Appareils vus, horodatage du dernier message |
| GET /api/devices/{device_id}/history | Historique de télémétrie (paramètre limit) |
| GET /api/alerts | Dernières alertes, les plus récentes d'abord |
| WebSocket /ws/alerts | Flux d'alertes en temps réel pour le dashboard |
| GET /api/devices/{device_id}/risk | Score de risque de l'appareil (0 à 100) |

La figure 9 représente le cheminement d'un message, de sa publication à son affichage.

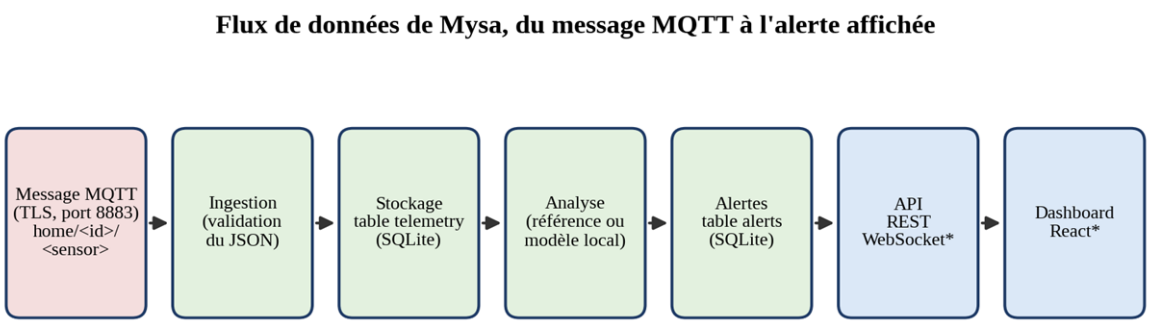



Figure 9 : Flux de données de Mysa

# Chapitre 8 : Installation et configuration

Ce chapitre décrit la réalisation étape par étape, dans l'ordre où elle peut être reproduite : d'abord l'infrastructure sécurisée (broker, réseau), puis les nœuds, puis le moteur, les modèles de référence, l'API, le dashboard et enfin le simulateur d'attaque. Chaque section indique l'état d'avancement réel, afin de distinguer ce qui est réalisé de ce qui reste à faire. Le tableau 8.1 en donne la synthèse.

## 8.1. Broker MQTT sécurisé

Cette étape répond directement aux vulnérabilités V-01 (absence de chiffrement) et V-02 (identifiants par défaut) du chapitre 4 : le broker n'accepte aucune connexion anonyme et chiffre toutes les communications. Elle s'exécute sur la machine virtuelle « hub » (Ubuntu Server).

### 8.1.1. Installer Mosquitto

D'abord, installer Mosquitto avec l'installateur Windows de mosquitto.org [21], puis ajouter les deux dossiers au PATH de la session.

### 8.1.2. Créer l'autorité de certification privée et le certificat du broker

Le certificat du broker est signé par une autorité de certification (CA) privée, propre au projet. Le nom d'hôte ou l'adresse IP utilisés par les clients pour joindre le broker doit figurer dans le certificat (champ subjectAltName), sans quoi la vérification échoue.

*New-Item -ItemType Directory -Force broker\certs | Out-Null; Set-Location broker\certs*

*openssl genrsa -out ca.key 2048*

*openssl req -new -x509 -days 365 -key ca.key -out ca.crt -subj "/CN=Mysa-CA"*

*openssl genrsa -out server.key 2048*

*openssl req -new -key server.key -out server.csr -subj "/CN=mysa-hub"*

*Set-Content -Path san.ext -Value "subjectAltName=IP:<ADRESSE_DU_HUB>" -Encoding ascii*

*openssl x509 -req -in server.csr -CA ca.crt -CAkey ca.key -CAcreateserial -out server.crt -days 365 -extfile san.ext*

*New-Item -ItemType Directory -Force C:\mosquitto\certs | Out-Null*

*Copy-Item ca.crt, server.crt, server.key C:\mosquitto\certs*

*icacls C:\mosquitto\certs\server.key /inheritance:r /grant:r "SYSTEM:(R)" "Administrators:(F)"*

Le dossier broker/certs/ et le fichier broker/passwd sont exclus du dépôt (.gitignore) : les clés privées et les mots de passe ne sont jamais publiés sur GitHub. Sous Windows, il n'existe ni chown ni chmod : la commande icacls réserve la lecture de la clé privée au service Mosquitto (compte SYSTEM) et aux administrateurs.

#### 8.1.3. Créer un compte par appareil

Un compte distinct est créé pour chaque nœud et pour le moteur, de façon à pouvoir restreindre leurs droits individuellement (étape 8.1.4).

*mosquitto_passwd -c C:\mosquitto\passwd mysa-engine*

*mosquitto_passwd C:\mosquitto\passwd esp32-sec-01*

*mosquitto_passwd C:\mosquitto\passwd esp32-cmf-01*

#### 8.1.4. Appliquer la configuration et les règles d'accès

La configuration du dépôt (broker/mosquitto.conf) désactive les connexions anonymes, n'ouvre que le port chiffré 8883 et référence le fichier de mots de passe et la liste de contrôle d'accès :

*listener 8883*

*certfile /etc/mosquitto/certs/server.crt*

*keyfile /etc/mosquitto/certs/server.key*

*allow_anonymous false*

*password_file /etc/mosquitto/passwd*

*acl_file /etc/mosquitto/acl.conf*

Le fichier broker/acl.conf applique le principe du moindre privilège : chaque nœud ne peut publier que sous ses propres topics et ne lit que ses propres commandes ; le moteur peut tout lire mais ne publie que des commandes.

*user esp32-sec-01*

*topic write home/esp32-sec-01/#*

*topic read  home/esp32-sec-01/cmd/#*

*user mysa-engine*

*topic read  home/#*

*topic write home/+/cmd/#*

*Copy-Item broker\mosquitto.conf C:\mosquitto\mosquitto.conf # sauvegarder au préalable le fichier d'origine*

*Copy-Item broker\acl.conf C:\mosquitto\acl.conf*

*New-NetFirewallRule -DisplayName "Mosquitto TLS 8883" -Direction Inbound -Protocol TCP -LocalPort 8883 -Action Allow*

*Restart-Service mosquitto*

*Get-Service mosquittoVérifier la sécurisation*

Tableau 24 : Tests de vérification du broker

| **Test** | **Commande (principe)** | **Résultat attendu** | **Résultat obtenu** |
|---|---|---|---|
| Connexion anonyme | mosquitto_sub sans identifiants, port 8883 | Refus : connexion non autorisée | |
| Connexion en clair | mosquitto_sub sans TLS, port 8883 | Échec de la poignée de main | |
| Connexion authentifiée | mosquitto_sub avec --cafile ca.crt et compte mysa-engine | Connexion établie, messages reçus | |
| Respect des ACL | esp32-sec-01 publie sous home/esp32-cmf-01/... | Message non délivré aux abonnés | |

Avec MQTT 3.1.1, un message publié sans autorisation est ignoré par le broker sans erreur renvoyée au publieur : la vérification se fait donc côté abonné, en constatant que le message n'arrive pas.

Figure 10 : Capture des tests de refus et de succès de connexion

## 8.2. Segmentation réseau en VLAN

La segmentation répond à V-04 (absence de segmentation) et limite le risque R-04 (pivot depuis un appareil compromis). Elle est d'abord simulée avec GNS3 et un routeur virtuel MikroTik RouterOS CHR, en attendant le routeur physique.

Tableau 25 : Plan de segmentation

| **VLAN** | **Rôle** | **Contenu** | **Sous-réseau** |
|---|---|---|---|
| 10 | Nœuds physiques | esp32-sec-01, esp32-cmf-01 | 192.168.10.0/24 |
| 20 | Appareils virtuels | Caméra, ampoule, prise simulées | 192.168.20.0/24 |
| 30 | Pile Mysa | Broker, moteur, API, base de données | 192.168.30.0/24 |
| 40 | Plateforme d'attaque (isolée) | Machine Kali | 192.168.40.0/24 |

### 8.2.1. Construire la topologie sous GNS3

L'image RouterOS CHR (section Cloud Hosted Router du site de MikroTik [29]) est importée dans GNS3 [28] sous la forme d'une machine QEMU : 128 Mo de mémoire vive suffisent, avec cinq interfaces réseau. La topologie comprend le routeur CHR, un commutateur GNS3 relié à ether2 (port dot1q vers le routeur, ports d'accès pour le VLAN 10 et le VLAN 20), le hub relié à ether3 (VLAN 30), la machine Kali reliée à ether4 (VLAN 40) et un nœud NAT relié à ether1 pour l'accès à Internet.

Les nœuds ESP32 physiques ne peuvent pas être branchés dans GNS3 : en simulation, ils sont représentés par leurs équivalents logiciels (Wokwi [34] ou scripts de simulation) rattachés au VLAN 10. Les noms d'interfaces ether1 à ether4 sont à vérifier avec la commande /interface print dans la console RouterOS.

La GNS3 VM et la machine Kali sont deux machines virtuelles distinctes. Dans Edit > Preferences > GNS3 VM, l'hyperviseur doit désigner la GNS3 VM officielle et non la machine Kali : une erreur vmrun à l'enregistrement des préférences indique en général que l'une a été sélectionnée à la place de l'autre.

### 8.2.2. Créer les interfaces VLAN sur le routeur

*/interface vlan add name=vlan10 vlan-id=10 interface=ether2*

*/interface vlan add name=vlan20 vlan-id=20 interface=ether2*

*/interface vlan add name=vlan30 vlan-id=30 interface=ether3*

*/interface vlan add name=vlan40 vlan-id=40 interface=ether4*

*/ip address add address=192.168.10.1/24 interface=vlan10*

*/ip address add address=192.168.20.1/24 interface=vlan20*

*/ip address add address=192.168.30.1/24 interface=vlan30*

*/ip address add address=192.168.40.1/24 interface=vlan40*

#### 8.2.3. Filtrer les flux inter-VLAN

Seul le flux MQTT chiffré des VLAN 10 et 20 vers le VLAN 30 est autorisé ; le reste est refusé. Les accès de la machine Kali vers les VLAN cibles ne sont ouverts que pendant l'exécution d'un scénario d'attaque.

*/ip firewall filter add chain=forward connection-state=established,related action=accept*

*/ip firewall filter add chain=forward in-interface=vlan10 out-interface=vlan30 protocol=tcp dst-port=8883 action=accept*

*/ip firewall filter add chain=forward in-interface=vlan20 out-interface=vlan30 protocol=tcp dst-port=8883 action=accept*

*/ip firewall filter add chain=forward action=drop comment="refus inter-VLAN par défaut"*

#### 8.2.4. Vérifier l'isolation

Depuis un appareil du VLAN 10 : le port 8883 du hub répond, tout autre port est inaccessible. Depuis le VLAN 40 (Kali) : aucun accès aux VLAN 10, 20 et 30 hors scénario d'attaque.

Résultats à compléter

Figure 11 : Topologie GNS3 avec les quatre VLAN

### 8.3. Firmware des nœuds ESP32

Chaque nœud publie ses mesures à période fixe en JSON, sur le port chiffré, avec son propre compte. Le projet PlatformIO est initialisé avec le fichier platformio.ini :

*[env:esp32dev]*

```
platform = espressif32
board = esp32dev
framework = arduino
monitor_speed = 115200
lib_deps = knolleary/PubSubClient
adafruit/DHT sensor library
```

Squelette du nœud « sécurité périphérique » (esp32-sec-01) ; les broches et les identifiants sont à adapter. L'horodatage est apposé par le moteur à la réception, ce qui évite de dépendre de l'horloge de l'ESP32.

```
#include <WiFi.h>
#include <WiFiClientSecure.h>
#include <PubSubClient.h>
const char* WIFI_SSID = "...";   const char* WIFI_PASS = "...";
const char* MQTT_HOST = "...";   // adresse du hub, présente dans le certificat
const int   MQTT_PORT = 8883;
const char* DEVICE_ID = "esp32-sec-01";
const char* MQTT_USER = "esp32-sec-01";  const char* MQTT_PASS = "...";
const int   PIR_PIN   = 13;            // à adapter au câblage
const unsigned long PERIOD_MS = 2000;
const char* CA_CERT = "-----BEGIN CERTIFICATE-----\n...\n-----END CERTIFICATE-----\n";
WiFiClientSecure net;
PubSubClient mqtt(net);
void connectMqtt() {
    while (!mqtt.connected()) {
        mqtt.connect(DEVICE_ID, MQTT_USER, MQTT_PASS);
        if (!mqtt.connected()) delay(2000);
```

```
        }
}

void publishSensor(const char* sensor, float value, const char* unit) {
    char topic[64], payload[160];
    snprintf(topic, sizeof(topic), "home/%s/%s", DEVICE_ID, sensor);
    snprintf(payload, sizeof(payload),
    "{\"device_id\":\"%s\",\"sensor\":\"%s\",\"value\":%.2f,\"unit\":\"%s\"}",
    DEVICE_ID, sensor, value, unit);
    mqtt.publish(topic, payload);
}

void setup() {
    pinMode(PIR_PIN, INPUT);
    WiFi.begin(WIFI_SSID, WIFI_PASS);
    while (WiFi.status() != WL_CONNECTED) delay(500);
    net.setCACert(CA_CERT);
    mqtt.setServer(MQTT_HOST, MQTT_PORT);
}

void loop() {
    connectMqtt();
    mqtt.loop();
    static unsigned long last = 0;
    if (millis() - last >= PERIOD_MS) {
        last = millis();
```

```
        publishSensor("pir", digitalRead(PIR_PIN), "bool");
    }
  }
```

Figure 12 : Schéma de câblage des deux nœuds

## 8.4. Ingestion MQTT et stockage

### 8.4.1. Préparer l'environnement Python

```
python -m venv .venv
.venv\Scripts\activate
pip install -r requirements.tx
Copy-Item .env.example .env      # puis renseigner les valeurs
```

Le fichier .env (non versionné) contient l'adresse du broker, le compte du moteur, l'activation de TLS, le chemin du certificat de la CA privée (MQTT_CA_CERT) et le chemin de la base (DB_PATH).

### 8.4.2. Le schéma de stockage

Deux tables sont créées automatiquement au démarrage, avec des index sur l'appareil et l'horodatage :

Tableau 26 : Tables SQLite

| **Table** | **Colonnes** |
|---|---|
| telemetry | id, device_id, sensor, value (réel), unit, ts |
| alerts | id, device_id, message, severity, ts |

### 8.4.3. Lancer le moteur d'ingestion

Le moteur s'abonne à home/# avec le compte mysa-engine, ignore les topics de commande, rejette les messages non JSON ou incomplets (appareil ou capteur manquant), enregistre chaque télémétrie valide, puis appelle l'analyse du flux concerné.

```
python -m engine.ingest
```

## 8.5. Moteur de détection comportementale

### 8.5.1. Caractéristiques par flux capteur

Pour chaque nouveau message, le moteur relit les 20 derniers messages du même capteur du même appareil. Tant que la fenêtre n'est pas pleine, aucune évaluation n'a lieu. Une fonction unique calcule les caractéristiques du tableau 6.7, aussi bien pour la télémétrie réelle que pour les datasets publics.

### 8.5.2. Modèle local

Un Isolation Forest (100 arbres, contamination de 5 %, graine fixe pour la reproductibilité) est entraîné par flux sur les sept caractéristiques locales, puis sauvegardé dans engine/models/<appareil>__<capteur>.joblib afin de survivre à un redémarrage. Il exige au moins 20 échantillons.

### 8.5.3. Orchestration des trois régimes

Pour chaque flux, analyzer.evaluate choisit le modèle qui décide (local s'il existe, sinon référence de la catégorie, sinon aucun), lève une alerte en cas d'anomalie, et alimente l'historique d'apprentissage uniquement avec des fenêtres normales, à raison d'un échantillon tous les 5 messages. Extrait du cœur de la décision :

```
result, source = None, None
if model.has_baseline(key):
        result, source = model.score(key, current), "modèle local"
elif st["ref"]:
        result = reference.score_reference(st["ref"], current)
        source = f"référence « {st['category']} »"

anomalous = bool(result and result["is_anomaly"])
if anomalous:
        insert_alert(device_id=device_id, message=..., severity="high")
        return                  # fenêtre anormale : exclue de l'apprentissage
```

Tableau 27 : Paramètres du moteur

| **Paramètre** | **Valeur** | **Rôle** |
|---|---|---|
| WINDOW | 20 messages | Taille de la fenêtre d'analyse |
| STRIDE | 5 messages | Un échantillon d'apprentissage tous les 5 messages |
| N_LOCAL_MIN | 20 échantillons | Seuil d'entraînement du premier modèle local |
| N_LOCAL_MAX | 200 échantillons | Taille de la fenêtre glissante d'apprentissage |
| REFIT_EVERY | 20 échantillons | Fréquence de ré-entraînement (affinage) |
| REF_CHECK_WINDOWS | 10 fenêtres | Fenêtres observées avant de juger la référence |
| REF_MAX_FLAG_RATE | 0,5 | Part d'anomalies au-delà de laquelle la référence est rejetée |

Ces valeurs sont des choix initiaux, non optimisés. Leur sensibilité sera discutée au chapitre 9.

### 8.5.4. Vérification de bout en bout

Avec Mosquitto de développement (sans TLS, MQTT_USE_TLS=false) et le moteur lancé, le script de simulation publie 150 messages normaux d'un capteur PIR puis une valeur aberrante:

*python scripts/simulate_device.py*

Le terminal du moteur affiche la progression de l'apprentissage puis une alerte, également consultable via GET /api/alerts.

Figure 13 : Capture du vérification effectué sur le prototype

### 8.5.5. Score de risque par appareil

Le score de risque résume l'état d'un appareil en un nombre de 0 à 100, lisible par un non-spécialiste. Il est calculé à partir des épisodes d'alerte récents de l'appareil : chaque épisode contribue selon sa gravité, et sa contribution décroît avec son âge, de sorte qu'un appareil redevenu normal voit son score revenir vers zéro. Les épisodes, plutôt que les alertes brutes, sont comptés afin que les fenêtres glissantes ne gonflent pas artificiellement le score (5.6).

```
# engine/risk.py

import math

WEIGHTS = {"low": 10, "medium": 20, "high": 40}   # poids par gravité

TAU_S = 30 * 60                                   # décroissance : 30 minutes


def risk_score(episodes):

    """episodes : liste de (gravité, âge en secondes) ; retourne un entier de 0 à 100."""

    total = sum(WEIGHTS.get(sev, 10) * math.exp(-age / TAU_S) for sev, age in episodes)    return min(100, round(total))
```

Trois niveaux de lecture sont proposés au dashboard : normal (0 à 24), à surveiller (25 à 59) et critique (60 à 100). Les poids, la constante de décroissance et les seuils sont des choix initiaux, à calibrer lors des campagnes du chapitre 9 ; les valeurs de gravité sont à aligner sur celles utilisées par le moteur. Le score est exposé par le point d'accès GET /api/devices/{device_id}/risk (8.7).

## 8.6. Modèles de référence et amorçage à froid

### 8.6.1. Télécharger les datasets

Les jeux de télémétrie TON_IoT sont téléchargés depuis la page officielle de l'UNSW (6.2.2) dans le dossier data/public/, exclu du dépôt (volume et conditions d'usage). Avant tout entraînement, vérifier les noms de colonnes et les valeurs réelles dans chaque fichier : le script convertit les valeurs textuelles (par exemple ouvert/fermé) en codes numériques.

### 8.6.2. Entraîner un modèle par catégorie

```
python scripts/train_reference.py --category mouvement –csv
data/public/IoT_Motion_Light.csv

python scripts/train_reference.py --category ouverture --csv
data/public/IoT_Garage_Door.csv

python scripts/train_reference.py --category environnemental --csv
data/public/IoT_Weather.csv --value-col temperature
```

Pour chaque catégorie, le script découpe la série en fenêtres de 20 lignes non chevauchantes, calcule les caractéristiques portables, entraîne l'Isolation Forest sur 80 % des fenêtres entièrement normales, puis évalue le modèle sur les 20 % restants (fausses alertes) et sur les fenêtres majoritairement composées d'attaques (détection). Il écrit le modèle et un fichier de métriques dans engine/models/reference/.

#### 8.6.3. Contrôler le résultat

Les métriques de chaque modèle sont reportées au tableau 9.3. Un modèle dont le taux de fausses alertes hors ligne est élevé est écarté ou réentraîné avant de servir d'amorce.

#### 8.6.4. Démarrage d'un nouvel appareil

Lorsqu'un nouvel appareil publie, categories.categorize associe chaque capteur à une catégorie (dht22 → environnemental, pir → mouvement) ; le modèle de référence correspondant est chargé s'il existe, et décide dès la première fenêtre complète de 20 messages. Un capteur sans catégorie (RFID, relais) suit le régime d'amorçage sans référence.

Vérification technique réalisée pendant le développement, sur des données synthétiques uniquement : l'association par catégorie, le chargement de la référence, la bascule vers le modèle local, l'exclusion des fenêtres anormales de l'apprentissage et le rejet d'une référence inadaptée fonctionnent comme décrit. Ces essais valident le fonctionnement du code, pas ses performances : aucun chiffre issu de données synthétiques ne figure dans ce mémoire.

### 8.7. API de consultation

*uvicorn api.main:app –reload*

*curl http://127.0.0.1:8000/api/devices*

*curl http://127.0.0.1:8000/api/alerts*

*curl http://127.0.0.1:8000/api/devices/esp32-sec-01/history?limit=50*

L'API lit la même base que le moteur ; la documentation interactive est disponible sur /docs. L'accès cross-origin est autorisé uniquement pour le serveur de développement du dashboard (port 5173). Le flux WebSocket /ws/alerts reste à réaliser.

Figure 14 : capture de /docs

Le point d'accès GET /api/devices/{device_id}/risk sera ajouté avec le score de risque (8.5.5).

## 8.8. Dashboard de supervision

Le dashboard consomme l'API et le futur flux WebSocket. Il vise deux profils (3.2) : l'occupant, qui veut un état lisible sans jargon, et l'analyste, qui veut le détail des alertes et un historique consultable.

### 8.8.1. Initialiser le projet

```
cd dashboard

npm create vite@latest . -- --template react

npm install recharts

npm run dev        # http://localhost:5173
```

### 8.8.2. Vues prévues

- **Vue d'ensemble** : liste des appareils avec statut (actif, silencieux) et dernier message, pour l'occupant ;
- **Alertes** : tableau des alertes avec appareil, capteur, gravité et source de la décision (référence ou modèle local), avec regroupement par épisode ;
- **Détail d'un appareil** : courbe de télémétrie et marqueurs d'alerte, pour l'analyste.

### 8.8.3. Consommer l'API REST

```
// dashboard/src/api.js

const API = "http://127.0.0.1:8000";

export const getDevices = () => fetch(`${API}/api/devices`).then((r) => r.json());

export const getAlerts = () => fetch(`${API}/api/alerts`).then((r) => r.json());

export const getHistory = (id, limit = 200) =>
fetch(`${API}/api/devices/${id}/history?limit=${limit}`).then((r) => r.json());
```

Ces trois fonctions alimentent respectivement la vue d'ensemble, le tableau des alertes et la courbe d'un appareil. Le serveur de développement du dashboard (port 5173) est le seul domaine autorisé par l'API en accès cross-origin (8.7).

### 8.8.4. Flux d'alertes en temps réel (WebSocket)

Côté API, le point d'accès /ws/alerts diffuse les nouvelles alertes. Une première version interroge la base chaque seconde ; un mécanisme de notification interne pourra la remplacer. La déconnexion du client lève une exception WebSocketDisconnect, à intercepter pour terminer proprement la boucle.

```
# api/main.py
import asyncio
from fastapi import WebSocket


@app.websocket("/ws/alerts")
async def ws_alerts(ws: WebSocket):
    await ws.accept()
    last_id = 0
    while True:
        for alert in storage.alerts_since(last_id):      # à ajouter dans engine/storage.py
            await ws.send_json(alert)
            last_id = alert["id"]
    await asyncio.sleep(1)
```

Côté dashboard, un hook React ouvre la connexion et empile les alertes reçues :

```
// dashboard/src/useAlerts.js
import { useEffect, useState } from "react";
export function useAlerts() {
    const [alerts, setAlerts] = useState([]);
    useEffect(() => {
        const ws = new WebSocket("ws://127.0.0.1:8000/ws/alerts");
```

```
        ws.onmessage = (e) => setAlerts((prev) => [JSON.parse(e.data),
    ...prev]);
        return () => ws.close();
    }, []);
    return alerts;
}
```

8.8.5. Principes d'interface

- Statuts lisibles : « Tout va bien », « À surveiller », « Alerte » plutôt que des valeurs brutes, pour le profil occupant.
- Alertes regroupées par épisode, le détail (valeur, source de décision, fenêtre) étant réservé à la vue analyste.
- Couleur doublée d'un libellé, pour rester lisible sans distinction de couleur.

Figure 15 : Capture du Dashboard

8.9. Simulateur d'attaque

Les scénarios s'exécutent depuis la machine Kali (VLAN 40), uniquement contre le prototype du projet, dans l'environnement isolé. Deux familles sont distinguées : les **tests d'intrusion** (TI) vérifient que les mesures préventives résistent ; les **scénarios comportementaux** (SC) vérifient que le moteur détecte une déviation quand un compte légitime est détourné ou un nœud compromis.

Tableau 28 : Tests d'intrusion

| **Réf.** | **Scénario** | **Risque** | **Outils** | **Observation attendue** |
|---|---|---|---|---|
| TI-01 | Écoute du trafic MQTT depuis le réseau | R-01 | Wireshark / tcpdump | Contenu illisible (TLS) ; contre-épreuve en clair sur la configuration initiale |
| TI-02 | Connexion avec identifiants par défaut ou par force brute | R-02 | hydra, clients MQTT | Connexions refusées ; tentatives visibles dans le journal du broker |
| TI-03 | Reprogrammation d'un nœud ESP32 | R-03 | Outil de flashage (manuel) | Nœud reprogrammé ; télémétrie altérée détectée par le moteur |

| | | | | |
|---|---|---|---|---|
| TI-04 | Mouvement latéral depuis un appareil compromis | R-04 | nmap | Flux inter-VLAN bloqués par le routeur |
| TI-05 | Accès physique au routeur | R-05 | Procédure manuelle | Constat de l'exposition ; hors automatisation |

Tableau 29 : Scénarios comportementaux

| **Réf.** | **Scénario** | **Ce qu'il éprouve** |
|---|---|---|
| SC-01 | Injection de valeurs aberrantes sur un flux existant (compte détourné) | Sensibilité aux pics ; modèle de référence et modèle local |
| SC-02 | Inondation de messages (rythme anormal) | Caractéristiques de rythme ; modèle local uniquement |
| SC-03 | Dérive progressive de la valeur | Capacité du ré-entraînement glissant à absorber ou à signaler la dérive |
| SC-04 | Attaque dès l'installation d'un appareil (pendant l'amorçage) | Hypothèse H1 (6.2.7) : référence contre apprentissage depuis zéro |
| SC-05 | Arrêt d'un appareil (silence) | Limite connue (5.6) : non détecté en l'état |

#### 8.9.1. Organiser le dépôt attack-lab

Le simulateur vit dans un dossier distinct du moteur, sans code partagé (7.2) :

- Attack-lab : README.md (plan d'adressage, prérequis)
- Scenarios :
  - ti01_sniff.sh, ti02_bruteforce.sh, ti04_scan.sh
  - sc01_spike.py, sc02_flood.py, sc03_drift.py
  - sc04_install.py, sc05_silence.py
  - run_all.py # orchestrateur
- logs : début et fin de chaque exécution (CSV)

#### 8.9.2. Ouvrir temporairement les flux depuis Kali

Le routeur refuse par défaut tout flux du VLAN 40 (8.2.3). Avant un scénario, une règle temporaire est ajoutée au-dessus de la règle de refus, puis supprimée à la fin de l'exécution :

*ip firewall filter add chain=forward in-interface=vlan40 out-interface=vlan10 action=accept comment="attaque-temp" place-before=[find where comment="refus inter-VLAN par défaut"]*

*ip firewall filter remove [find where comment="attaque-temp"]*

### 8.9.3. Écrire les scénarios

Chaque scénario est un script court, relié à un risque (R-xx) et à un identifiant (TI-xx ou SC-xx). Trois exemples :

- TI-04 : mouvement latéral (scan depuis un appareil compromis) : *nmap -Pn -sT -p 1-1024 192.168.30.0/24 -oN logs/ti04_scan.txt*
- TI-02 : force brute sur les identifiants MQTT (syntaxe à valider selon la version d'hydra) : *hydra -l esp32-cmf-01 -P wordlist.txt -s 8883 -S <ADRESSE_DU_HUB> mqtt*
- SC-01 : compte détourné publiant des valeurs aberrantes :

*import json, time*

*import paho.mqtt.client as mqtt*

*c = mqtt.Client(client_id="esp32-cmf-01") # paho-mqtt 2.x : mqtt.Client(mqtt.CallbackAPIVersion.VERSION2, ...)*

*c.username_pw_set("esp32-cmf-01", "<mot_de_passe>")*

*c.tls_set(ca_certs="ca.crt")*

*c.connect("<ADRESSE_DU_HUB>", 8883)*

*c.loop_start()*

*for _ in range(30):*

*msg = {"device_id": "esp32-cmf-01", "sensor": "temperature", "value": 95.0, "unit": "C"}*

*c.publish("home/esp32-cmf-01/temperature", json.dumps(msg))*

*time.sleep(2)*

Les identifiants du compte détourné sont ceux du nœud ciblé, créés en 8.1.3 ; le fichier ca.crt est celui produit en 8.1.2. Le nom du capteur doit correspondre à celui publié par le firmware (8.3), afin que le flux attaqué soit celui que le moteur surveille.

### 8.9.4. Orchestrer et journaliser

L'orchestrateur exécute les scénarios en séquence, ouvre puis ferme la règle temporaire, et consigne dans logs/ l'instant de début et de fin de chaque exécution. Le délai de détection se calcule ensuite comme l'écart entre le début de l'attaque et la première alerte enregistrée dans la table alerts.

```
# run_all.py (squelette)
import csv, subprocess, datetime as dt
  N_RUNS = 5   #
  SCENARIOS = [("SC-01", ["python", "scenarios/sc01_spike.py"]),
                        ("TI-04", ["bash", "scenarios/ti04_scan.sh"])]
  now = lambda: dt.datetime.now(dt.timezone.utc).isoformat()

  with open("logs/runs.csv", "a", newline="") as f:
      w = csv.writer(f)
      for ref, cmd in SCENARIOS:
            for run in range(1, N_RUNS + 1):
                  start = now()
                  subprocess.run(cmd, check=False)
                  writerow([ref, run, start, now()])
```

Figure 16 : Capture d'une exécution de l'orchestrateur

# Chapitre 9 : Test et validation

Ce chapitre définit le protocole de validation et réserve la place des résultats, qui seront renseignés après exécution sur le prototype. Aucune valeur n'est avancée avant mesure.

## 9.1. Protocole et mesures

- **Environnement** : version du dépôt (commit), versions de Python et scikit-learn, topologie réseau, appareils actifs, période de publication de chaque capteur
- **Taux de détection** : part des fenêtres ou épisodes malveillants ayant déclenché au moins une alerte.
- **Taux de fausses alertes** : alertes levées pendant les périodes sans attaque, rapportées au nombre de fenêtres normales évaluées.
- **Délai de détection** : durée entre le début effectif d'une attaque et la première alerte correspondante.
- **Épisodes d'alerte** : alertes consécutives séparées de moins de [durée] regroupées en un seul épisode, car les fenêtres glissantes multiplient les alertes d'une même déviation (5.6).
- **Répétitions** : chaque scénario est exécuté [N] fois ; les résultats sont présentés avec leur dispersion.

## 9.2. Tests d'intrusion

Tableau 30 : Résultats des tests d'intrusion

| Réf. | Résultat attendu | Résultat obtenu | Conclusion |
|---|---|---|---|
| TI-01 | Contenu illisible | | |
| TI-02 | Connexions refusées | | |
| TI-03 | Altération détectée | | |
| TI-04 | Flux bloqués | | |
| TI-05 | Exposition constatée | | |

La figure 9.1 présente le résultat d'un scan réalisé depuis la machine Kali lors du test TI-04.

Figure 17 : Résultat d'un scan nmap depuis la machine Kali (TI-04)

9.3. Évaluation de la détection comportementale

Les scénarios SC-01 à SC-05 sont exécutés dans deux configurations — apprentissage depuis zéro, puis référence suivie du modèle local, afin de tester les hypothèses H1 à H3.

Tableau 31 : Détection comportementale par configuration

| **Scénario** | **Configuration** | **Détection** | **Fausses alertes** | **Délai** | **Épisodes** |
|---|---|---|---|---|---|
| SC-01 | Depuis zéro | | | | |
| SC-01 | Référence + local | | | | |
| SC-02 | Depuis zéro | | | | |
| SC-02 | Référence + local | | | | |
| SC-04 | Depuis zéro | | | | |
| SC-04 | Référence + local | | | | |

La figure 9.2 montre l'alerte affichée sur le dashboard lors du scénario SC-01.

Figure 18 : Alerte affichée sur le dashboard lors du scénario SC-01

9.4. Évaluation hors ligne des modèles de référence

Tableau 32 : Métriques des modèles de référence sur TON_IoT

| **Catégorie** | **Dataset** | **Fenêtres d'entraînement** | **Test normal / attaque** | **Fausses alertes** | **Détection** |
|---|---|---|---|---|---|
| mouvement | IoT_Motion_Light | 15 416 | 3 854 / 3 258 | 5,2 % | 2,1 % |
| ouverture | IoT_Garage_Door | 18 462 | 4 616 / 3 881 | 3,6 % | 2,6 % |
| environnemental | IoT_Weather | 22 244 | 5 562 / 4 614 | 5,0 % | 8,4 % |

Le taux de fausses alertes est conforme au réglage du modèle (contamination de 5 %). Le taux de détection est faible dans les trois cas, et inférieur ou voisin du taux de fausses alertes : les modèles ne distinguent pas les attaques étiquetées du dataset. Pour comprendre pourquoi, on

mesure pour chaque caractéristique la capacité à séparer fenêtres normales et fenêtres d'attaque (aire sous la courbe ROC, AUC : 0,5 = aucune séparation, 1 = séparation parfaite).

Tableau 33 : Séparation normal/attaque par caractéristique

| **Caractéristique** | **Type** | **mouvement** | **ouverture** | **environnemental** |
|---|---|---|---|---|
| mean_abs_delta | portable | 0,583 | 0,502 | 0,538 |
| std_value | portable | 0,509 | 0,501 | 0,651 |
| unique_ratio | portable | 0,502 | 0,508 | 0,522 |
| cv_interval | locale | 0,625 | 0,546 | 0,512 |
| mean_value | locale | 0,505 | 0,501 | 0,516 |
| mean_interval_s | locale | 0,915 | 0,894 | 0,900 |
| std_interval_s | locale | 0,924 | 0,720 | 0,787 |
| Modèle de référence (score) | | 0,462 | 0,488 | 0,689 |

Tableau 34 : Cadence des lignes, fenêtres normales et d'attaque

| **Mesure** | **mouvement** | **ouverture** | **environnemental** |
|---|---|---|---|
| Lignes à horodatage identique, normal | 62,1 % | 78,0 % | 76,3 % |
| Lignes à horodatage identique, attaque | 17,8 % | 22,9 % | 38,3 % |
| Intervalle moyen par fenêtre (médiane), normal | 0,68 s | 0,16 s | 0,53 s |
| Intervalle moyen par fenêtre (médiane), attaque | 2,37 s | 1,84 s | 1,79 s |

Trois constats ressortent. Premièrement, les caractéristiques portables, qui décrivent la dynamique des valeurs, ne séparent pratiquement pas les classes (AUC de 0,50 à 0,58), sauf l'écart-type de la température (0,65) : les attaques de ces datasets n'altèrent pas les valeurs mesurées, ce qui explique la détection quasi nulle. Deuxièmement, la cadence sépare nettement

les classes dans les trois fichiers (AUC de 0,72 à 0,92 ; 0,89 à 0,92 pour l'intervalle moyen). Troisièmement, ce contraste est le même pour trois capteurs physiquement différents, ce qui suggère une propriété de la façon dont les phases normales et d'attaque ont été enregistrées plutôt qu'un effet des attaques sur les capteurs ; c'est une interprétation, non une démonstration. La cadence est de toute façon une caractéristique propre à chaque appareil : elle est exclue des modèles de référence (6.2.5) et relève du modèle local. Ces caractéristiques n'ont pas été sélectionnées en fonction de ces résultats : le jeu portable a été fixé avant leur mesure, et le diagnostic sert à comprendre les données, non à régler le modèle sur les étiquettes d'attaque.

## 9.5. Discussion et limites

# Conclusion

Ce mémoire a présenté la conception et la réalisation de Mysa, une architecture autonome de cybersécurité comportementale destinée aux écosystèmes de maisons intelligentes. La démarche a combiné une analyse de l'existant justifiant le choix d'une approche comportementale, une architecture en couches inspirée des modèles de référence de l'IoT intégrant une segmentation réseau par VLAN, puis la réalisation d'un prototype associant appareils physiques et virtuels, un moteur de détection et une plateforme d'attaque automatisée.

Les résultats obtenus permettent d'évaluer la capacité du système à détecter des comportements anormaux sans connaissance préalable des signatures d'attaque, tout en mettant en évidence certaines limites, notamment la fenêtre d'exposition initiale propre à tout système fondé sur l'apprentissage d'une baseline, partiellement atténuée par la stratégie d'amorçage à froid mise en œuvre.

Plusieurs perspectives se dégagent de ce travail. Sur le plan technique, l'architecture pourrait être enrichie par l'intégration de modèles de détection par apprentissage automatique plus avancés, par l'élargissement du parc d'appareils physiques supervisés, et par le déploiement effectif sur le routeur Mikrotik physique en remplacement de la simulation RouterOS CHR. Sur le plan applicatif, une évolution vers un déploiement en conditions réelles, au sein d'un foyer effectif plutôt que d'un prototype contrôlé, permettrait de confronter l'approche comportementale à la variabilité d'un usage domestique non scénarisé.

**Références bibliographiques**

[1] ANSSI, EBIOS Risk Manager – Le guide, 2018, Agence nationale de la sécurité des systèmes d'information, Paris

[2] ISO/IEC 27005:2022, Information security, cybersecurity and privacy protection — Guidance on managing information security risks, 2022, ISO, Genève

[3] UIT-T, Recommandation Y.2060 – Vue d'ensemble de l'Internet des objets, 2012, Union internationale des télécommunications, Genève

[4] A. Al-Fuqaha, M. Guizani, M. Mohammadi, M. Aledhari, M. Ayyash, Internet of Things: A Survey on Enabling Technologies, Protocols, and Applications, 2015, IEEE Communications Surveys & Tutorials, vol. 17, n° 4, pp. 2347-2376

[5] oneM2M, TS-0001 – Functional Architecture, oneM2M Partners Type 1

[6] ETSI, TS 102 690 – Machine-to-Machine communications (M2M); Functional architecture, version 2.1.1, 2013, ETSI, Sophia Antipolis

[7] OASIS, MQTT Version 3.1.1, OASIS Standard, 2014

[8] Z. Shelby, K. Hartke, C. Bormann, The Constrained Application Protocol (CoAP), RFC 7252, 2014, IETF

[9] R. Fielding, M. Nottingham, J. Reschke, HTTP Semantics, RFC 9110, 2022, IETF

[10] F. T. Liu, K. M. Ting, Z.-H. Zhou, Isolation Forest, 2008, Proceedings of the 8th IEEE International Conference on Data Mining (ICDM), pp. 413-422

[11] F. Pedregosa et al., Scikit-learn: Machine Learning in Python, 2011, Journal of Machine Learning Research, vol. 12, pp. 2825-2830

[12] S. J. Pan, Q. Yang, A Survey on Transfer Learning, 2010, IEEE Transactions on Knowledge and Data Engineering, vol. 22, n° 10, pp. 1345-1359

[13] A. Alsaedi, N. Moustafa, Z. Tari, A. Mahmood, A. Anwar, TON_IoT Telemetry Dataset: A New Generation Dataset of IoT and IIoT for Data-Driven Intrusion Detection Systems, 2020, IEEE Access, vol. 8, pp. 165130-165150

[14] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, A. A. Ghorbani, CICIoT2023: A Real-Time Dataset and Benchmark for Large-Scale Attacks in IoT Environment, 2023, Sensors, vol. 23, n° 13, article 5941

**Références webographiques**

[15] https://firewalla.com, Firewalla, présentation des produits, consulté le 20 octobre 2026

[16] https://www.bitdefender.com, Bitdefender BOX, consulté le 20 octobre 2026

[17] https://www.fing.com, Fingbox, consulté le 20 octobre 2026

[18] https://docs.platformio.org, PlatformIO Documentation, consulté le 20 octobre 2026

[19] https://docs.espressif.com/projects/esp-idf, ESP-IDF Programming Guide, consulté le 20 octobre 2026

[20] https://micropython.org, MicroPython, consulté le 20 octobre 2026

[21] https://mosquitto.org, Eclipse Mosquitto, consulté le 20 octobre 2026

[22] https://riverml.xyz, River : machine learning for streaming data, consulté le 20 octobre 2026

[23] https://fastapi.tiangolo.com, FastAPI, consulté le 20 octobre 2026

[24] https://www.sqlite.org, SQLite Documentation, consulté le 20 octobre 2026

[25] https://react.dev, React, consulté le 20 octobre 2026

[26] https://recharts.org, Recharts, consulté le 20 octobre 2026

[27] https://www.vmware.com, VMware Workstation, consulté le 20 octobre 2026

[28] https://www.gns3.com, GNS3, consulté le 20 octobre 2026

[29] https://help.mikrotik.com, RouterOS Documentation, consulté le 20 octobre 2026

[30] https://www.kali.org/docs, Kali Linux Documentation, consulté le 20 octobre 2026

[31] https://github.com/Reinitha18/Mysa, Dépôt du projet Mysa, consulté le 20 octobre 2026

[32] https://research.unsw.edu.au/projects/toniot-datasets, TON_IoT datasets, consulté le 20 octobre 2026

[33] https://www.unb.ca/cic/datasets/iotdataset-2023.html, CICIoT2023 dataset, consulté le 20 octobre 2026

[34] https://wokwi.com, Wokwi ESP32 Simulator, consulté le 20 octobre 2026

# Glossaire

ACL (liste de contrôle d'accès) : ensemble de règles définissant, pour chaque compte du broker, les topics qu'il peut lire ou écrire.

Amorçage à froid : stratégie consistant à démarrer la détection d'un nouvel appareil à partir d'un modèle de référence plutôt que d'un modèle vide, afin de réduire la fenêtre d'exposition initiale.

Baseline comportementale : profil d'activité normal établi pour un appareil à partir de l'observation continue de sa télémétrie.

Broker MQTT : serveur intermédiaire assurant la réception et la redistribution des messages publiés par les appareils selon le modèle publication/abonnement.

Catégorie d'appareil : regroupement de capteurs de même nature (mouvement, ouverture, environnemental) auquel est associé un modèle de référence.

Compte détourné : compte légitime d'un appareil utilisé par un attaquant pour publier de fausses mesures.

Empoisonnement de la baseline : introduction, pendant l'apprentissage, de mesures anormales qui sont alors apprises comme normales.

Épisode d'alerte : ensemble d'alertes consécutives rapprochées, regroupées en une seule déviation.

Fausse alerte : alerte levée en l'absence de toute attaque ou déviation réelle.

Fenêtre d'exposition : période initiale, propre à tout système d'apprentissage, durant laquelle aucune détection fiable n'est encore possible faute de baseline établie.

Fenêtre glissante : suite de messages consécutifs (20 dans le prototype) sur laquelle sont calculées les caractéristiques analysées.

Isolation Forest : algorithme non supervisé de détection d'anomalies qui isole les observations atypiques par partitionnements aléatoires successifs.

Modèle de référence : modèle de détection pré-entraîné sur une catégorie d'appareils à partir de données publiques, utilisé comme point de départ lors de l'amorçage à froid.

Modèle local : modèle entraîné sur la télémétrie réelle d'un appareil donné.

Moindre privilège : principe selon lequel chaque compte ne reçoit que les droits strictement nécessaires à sa fonction.

Pare-feu inter-VLAN : ensemble de règles encadrant les flux autorisés entre deux segments réseau distincts.

Scénario comportemental : test vérifiant que le moteur détecte une déviation, par exemple celle d'un compte détourné ou d'un nœud compromis.

Score de risque : indicateur synthétique, de 0 à 100, traduisant le niveau d'anomalie récemment observé pour un appareil donné.

Segmentation réseau : division d'un réseau en sous-segments isolés (VLAN) afin de restreindre la propagation du trafic et des menaces.

Télémétrie : ensemble des données mesurées et transmises par un appareil connecté pour décrire son activité.

Test d'intrusion : tentative d'attaque contrôlée, menée contre le prototype pour vérifier que les mesures préventives résistent.

TLS (Transport Layer Security) : protocole de chiffrement et d'authentification des échanges entre les appareils et le broker.

Transfer learning : technique d'apprentissage automatique consistant à réutiliser un modèle déjà entraîné sur une tâche proche comme point de départ pour une nouvelle tâche.

VLAN (réseau local virtuel) : segment logique d'un réseau physique permettant d'isoler des groupes d'appareils entre eux.

# Annexes

Les annexes regroupent des éléments utiles à la compréhension de la réalisation, qui ne figurent pas dans le canevas type.

Annexe A : Configuration du broker et du réseau (mosquitto.conf, acl.conf, configuration RouterOS).

Annexe B : Extraits du code du moteur de détection (caractéristiques, orchestration des régimes), dépôt GitHub [31].

Annexe C : Catalogue des scénarios d'attaque et journaux d'exécution.

# Tables des matières

**Curriculum Vitae**.....I

**Sommaire** .....IV

**Remerciements**.....VII

**Liste des figures** ..... VIII

**Listes des tableaux**.....IX

**Listes des abréviations** ..... X

**Introduction générale**..... 1

**Partie I : PRESENTATIONS** ..... 2

Chapitre 1 : Présentation de l'ENI ..... 3

1.1. Information d'ordre générale ..... 3

1.2. Missions et historiques..... 3

1.3. Organigramme institutionnel..... 5

1.4. Domaine de spécialisation..... 6

1.5. Architecture des formations pédagogiques ..... 7

1.6. Relation de l'ENI avec les organismes externes ..... 9

1.7. Débouchés professionnels et diplômés ..... 9

1.8. Ressources humaines..... 12

Chapitre 2: Présentation de l'établissement d'accueil..... 13

**2.1. Description et statuts :** ..... 13

**2.2. Activités**..... 14

**2.3. Contacts et adresses**..... 15

**2.4. Nos partenaires**..... 15

**2.5. Organigramme** ..... 16

Chapitre 3 : Description du projet..... 17

**3.1. Formulation** ..... 17

**3.2. Objectif et besoins de l'utilisateur** ..... 17

**3.3. Moyens nécessaires à la réalisation du projet (Humain, Matériel, Logiciel)** 18
3.3.1. Moyens humains : ..... 18
3.3.2. Moyens matériels : ..... 18
3.3.3. Moyens logiciels : ..... 18
**3.4. Résultats attendus** ..... 18
**3.5. Chronogramme de travail** ..... 19
**PARTIE II : ANALYSE ET CONCEPTION** ..... 20
Chapitre 4 : Analyse préalable ..... 21
4.1. Analyse de l'existant ..... 21
4.1.1. Collecte des données existantes ..... 21
4.1.2. Analyse des technologies et processus ..... 21
4.1.3. Recueil des risques et vulnérabilités ..... 22
4.1.4. Cartographie de l'écosystème ..... 23
4.1.5. Sessions de feedback ..... 24
4.1.6. Rapport d'analyse et recommandations ..... 25
4.1.7. Mise à jour continue ..... 25
4.2. Critique de l'existant (points forts et points faibles) ..... 25
4.3. Proposition de solutions ..... 26
Chapitre 5 : Modèle et architecture de l'IoT ..... 29
5.1. Cadre conceptuel et fondements du modèle IoT ..... 29
5.2. Conception et rôle de la couche perception (capteurs et dispositifs) ..... 29
5.3. Technologies de connectivité et protocoles de transmission dans la couche réseau 29
5.4. Modélisation schématique d'une architecture IoT appliquée ..... 30
5.5. Analyse comparative des modèles de référence normalisés ..... 31
5.6. Limites techniques et défis d'ingénierie de l'architecture IoT ..... 32
Chapitre 6 : Études et choix des outils ..... 33

6.1. Outils utilisés ..... 33
6.1.1. Outils de développement firmware ..... 33
6.1.2. Protocole et broker de communication IoT ..... 33
6.1.3. Outils d'apprentissage automatique pour la détection d'anomalies ..... 35
6.1.4. Framework backend et API ..... 35
6.1.5. Stockage de la télémétrie ..... 35
6.1.6. Framework frontend et visualisation ..... 36
6.1.7. Environnement de virtualisation et de simulation réseau ..... 36
6.1.8. Outils de test d'intrusion ..... 36
6.1.9. Outils de gestion de projet et de version ..... 36
6.2. Données et stratégie d'amorçage à froid ..... 37
6.2.1. Problème : le démarrage à froid ..... 37
6.2.2. Datasets publics retenus ..... 37
6.2.3. Principe : un modèle par catégorie, jamais de mélange ..... 38
6.2.4. Association capteur–catégorie ..... 40
6.2.5. Caractéristiques portables et caractéristiques locales ..... 40
6.2.6. Garde-fous et limites ..... 41
6.2.7. Protocole d'évaluation prévu ..... 42
6.2.8. Synthèse du choix technologique ..... 42
**PARTIE III : RÉALISATION** ..... 43
Chapitre 7 : Présentation de l'environnement ..... 44
7.1. Prototype de maison intelligente ..... 44
7.2. Plateforme d'attaque ..... 45
7.3. Présentation de Mysa ..... 45
Chapitre 8 : Installation et configuration ..... 48
8.1. Broker MQTT sécurisé ..... 48
8.1.1. Installer Mosquitto ..... 48

8.1.2. Créer l'autorité de certification privée et le certificat du broker ..... 48
8.1.3. Créer un compte par appareil ..... 49
8.1.4. Appliquer la configuration et les règles d'accès ..... 49
8.1.5. Vérifier la sécurisation ..... 49
8.2. Segmentation réseau en VLAN ..... 51
8.2.1. Construire la topologie sous GNS3 ..... 51
8.2.2. Créer les interfaces VLAN sur le routeur ..... 51
8.2.3. Filtrer les flux inter-VLAN ..... 52
8.2.4. Vérifier l'isolation ..... 52
8.3. Firmware des nœuds ESP32 ..... 52
8.4. Ingestion MQTT et stockage ..... 55
8.4.1. Préparer l'environnement Python ..... 55
8.4.2. Le schéma de stockage ..... 55
8.4.3. Lancer le moteur d'ingestion ..... 55
8.5. Moteur de détection comportementale ..... 56
8.5.1. Caractéristiques par flux capteur ..... 56
8.5.2. Modèle local ..... 56
8.5.3. Orchestration des trois régimes ..... 56
8.5.4. Vérification de bout en bout ..... 57
8.5.5. Score de risque par appareil ..... 57
8.6. Modèles de référence et amorçage à froid ..... 58
8.6.1. Télécharger les datasets ..... 58
8.6.2. Entraîner un modèle par catégorie ..... 58
8.6.3. Contrôler le résultat ..... 59
8.6.4. Démarrage d'un nouvel appareil ..... 59
8.7. API de consultation ..... 59
8.8. Dashboard de supervision ..... 60

8.8.1. Initialiser le projet ..... 60
8.8.2. Vues prévues ..... 60
8.8.3. Consommer l'API REST ..... 60
8.8.4. Flux d'alertes en temps réel (WebSocket) ..... 61
8.8.5. Principes d'interface ..... 62
8.9. Simulateur d'attaque (à réaliser) ..... 62
8.9.1. Organiser le dépôt attack-lab ..... 63
8.9.2. Ouvrir temporairement les flux depuis Kali ..... 63
8.9.3. Écrire les scénarios ..... 64
8.9.4. Orchestrer et journaliser ..... 65
Chapitre 9 : Test et validation ..... 66
9.1. Protocole et mesures ..... 66
9.2. Tests d'intrusion ..... 66
9.3. Évaluation de la détection comportementale ..... 67
9.4. Évaluation hors ligne des modèles de référence ..... 67
9.5. Discussion et limites ..... 67
**Conclusion** ..... 70
**Références bibliographiques** ..... XIII
**Références webographiques** ..... XV
**Glossaire** ..... XVI
**Annexes** ..... XVIII
**Tables des matières** ..... XIX
**Résumé** ..... XXIV
**Abstract** ..... XXIV

# Résumé

Ce mémoire présente Mysa, une architecture autonome de cybersécurité comportementale destinée aux écosystèmes de maisons intelligentes. Face aux limites de la détection par signatures dans un parc d'objets connectés hétérogène, l'approche proposée modélise le comportement normal de chaque appareil à partir de sa télémétrie MQTT, au moyen d'un algorithme non supervisé (Isolation Forest), et réduit la fenêtre d'exposition initiale grâce à des modèles de référence entraînés sur des données publiques (TON_IoT). Un prototype associant deux nœuds ESP32 physiques et des appareils simulés, un broker sécurisé, une segmentation réseau en VLAN, un moteur de détection, une API de consultation et une plateforme d'attaque automatisée a été conçu pour valider l'approche.



**Mots clés :** amorçage à froid, cybersécurité comportementale, détection d'anomalies, Isolation Forest, maison intelligente, MQTT, segmentation réseau



# Abstract

This thesis presents Mysa, an autonomous behavioral cybersecurity architecture designed for smart home ecosystems. Given the limitations of signature-based detection in a heterogeneous connected-device environment, the proposed approach models the normal behavior of each device from its MQTT telemetry using an unsupervised algorithm (Isolation Forest), and shortens the initial exposure window with reference models trained on public data (TON_IoT). A prototype combining two physical ESP32 nodes and simulated devices, a secured broker, VLAN-based network segmentation, a detection engine, a query API and an automated attack platform was designed to validate the approach.



**Keywords :** anomaly detection, behavioral cybersecurity, cold start, Isolation Forest, MQTT, network segmentation, smart home